统一权限管理系统
需求与详细设计说明书

版本 2.0

2026 年 10 月 26 日

目录

1 引言 4
1.1 编写目的 4
1.2 项目背景 4
1.3 定义 4
1.4 参考资料 6
2 任务概述 6
2.1 目标 6
2.2 运行环境 7
2.3 条件与限制 7
3 数据描述 9
3.1 领域模型 9
3.2 上下文数据流 10
3.3 一级数据流 11
3.4 关键二级数据流 13
3.5 数据库设计 14
4 功能需求 20
4.1 功能划分 20
4.2 功能描述 21
4.2.1 管理员登录 22
4.2.2 员工统一登录 24
4.2.3 跨系统会话复用 26
4.2.4 统一退出 27
4.2.5 组织维护 29
4.2.6 员工维护 30
4.2.7 跨部门调动 32
4.2.8 管理员任命 34
4.2.9 系统及部门可用范围 35
4.2.10 权限目录接收与失败重报 37
4.2.11 全局角色模板 39
4.2.12 部门角色 40
4.2.13 角色分配与替换 42
4.2.14 撤销角色 44
4.2.15 运行时鉴权 45
4.2.16 查询有效角色与权限 47
4.2.17 审计查询与导出 48
4.3 业务流程 49
4.3.1 总体流程 49
4.4 模块与对象详细设计 50
4.5 接口与关键处理设计 52
5 性能需求 54
5.1 数据精确度 54

5.2 时间特性 55
5.3 适应性 56
6 运行需求 56
6.1 软件接口 56
6.2 故障处理 57
6.3 部署设计 58
6.4 测试与报告 59
7 其它需求 59
7.1 可用性 59
7.2 权限隔离与安全 59
7.3 审计与一致性 60
7.4 功能验收 60
7.5 课程演示与文档检查 62

1 引言

1.1 编写目的

本文规定统一权限管理系统的业务需求、数据库结构和详细设计，供开发、测试及课程检查使用。功能采用“用例表、场景流程、方法与 URL、必要备注”的形式；数据库和接口依据当前代码与 Flyway V1 至 V4 核对。

业务行为沿用《需求规格说明书 2.1》。分析推导、候选方案与学习练习保留在配套 Markdown 指南中；本文集中记录范围、约束、实际设计及验证条件。部署和测试结果见口试交付验收报告。

1.2 项目背景

集团现有多个由不同开发商建设的独立业务系统。各系统分别维护账号与权限，员工重复登录，管理人员分散授权，集团难以集中了解员工拥有哪些访问权限。

本项目统一维护员工身份、业务系统权限目录和角色授权。员工在业务系统选择统一账号登录，浏览器跳转至统一认证入口。业务系统取得经平台验证的身份后，在执行受控操作前向平台查询权限。最高管理员与部门管理员通过管理后台维护配置。

早高峰期间，10,000 名员工可能在 60 秒内发起登录，之后继续产生鉴权请求。平台承担认证、会话和权限判断压力。外部业务系统承担业务数据处理及业务操作执行。

外部系统直接使用统一身份与实时鉴权，平台不推送外部账号或角色副本。

1.3 定义

术语	定义
UPMS / 平台	统一权限管理系统，包含统一认证入口、管理后台和供业务系统使用的身份验证与鉴权能力。
认证	确认登录者身份。本 Demo 使用用户名与手机号同时匹配。
鉴权	判断已识别员工能否在某个业务系统执行某个功能点的某种操作。
统一会话	员工登录后建立的身份状态。同一浏览器可复用，固定有效期最多 8 小时。
登录结果	供发起登录的已登记系统验证员工身份的结果，需限制接收系统、有效期和重复使用。

术语	定义
公司 / 部门	公司包括总公司和 9 个分公司；部门是公司下的末级管理单元。
最高管理员	固定平台管理身份，可管理全部数据与功能。
部门管理员	固定平台管理身份，只维护所属部门员工、部门角色及授权。
外部系统	独立建设的业务系统，接入统一登录与实时鉴权，并上报自己的权限目录。
部门可用系统	最高管理员允许某部门配置角色和员工授权的系统集合。它不直接授予员工权限。
权限项	某系统中一个“功能点 + 操作动作”组合。
全局角色模板	最高管理员维护的、属于一个系统的角色权限样板，不能直接分配给员工。
部门角色	属于一个部门及一个系统的权限集合，员工通过它取得权限。
有效权限	员工、系统、部门可用范围、分配、角色和权限项均有效时，当前角色提供的权限。
RBAC0	员工通过角色取得权限；本期无角色继承、直接个人权限及多角色合并。
业务数据范围	“本人”等对业务记录的限制，由外部系统结合统一身份执行。
管理范围	部门管理员能管理哪些员工和配置，与业务数据范围分别校验。
P95	95% 的测量样本耗时不超过该值。
技术失败	超时、连接失败、非预期服务错误或未完成预期流程。预期权限拒绝不属于技术失败。

用例编号采用 UPMS-REQ-<业务域>-<序号>，序号在业务域内从 001 开始。

业务域	代码	范围
身份认证与会话	AUTH	后台登录、员工登录、会话复用、统一退出
组织 / 员工 / 管理员	ORG / EMP / ADM	基础数据、调动、管理员任命
外部系统	SYS	系统登记、启停、部门可用范围

业务域	代码	范围
权限目录	PERM	目录接收、变更、停用、失败重报
角色 / 授权	ROLE / GRANT	模板、部门角色、角色分配及撤销
运行时鉴权	AUTHZ	操作权限判断及故障拒绝
查询 / 审计	QUERY / AUDIT	有效权限查询、日志筛选与导出

功能验收编号为 ACC-F-<序号>，性能验收编号为 ACC-P-<序号>。

1.4 参考资料

资料	用途
PayReqSPEC.pdf	七章结构、功能划分、用例表格和业务流程格式。
市政公司员工信息表.xlsx	10,000 名员工及身份、组织、岗位资料。
市政公司部门信息表.xlsx	公司与部门的初始化归属。
市政公司应用软件功能权限清单.xlsx	系统、模块、功能点及五类初始岗位权限。
厦门大学信息门户及 统一身份认证页	统一登录跳转的交互参考。仅借鉴已观察到的门户跳转与返回方式，不推断其内部鉴权实现。
本项目确认的需求基线	Demo 登录方式、管理角色、授权边界、性能及演示范围。

2 任务概述

2.1 目标

1. 集中维护组织和员工身份，管理员按管理范围维护数据。
2. 为多个独立系统提供统一登录，同一浏览器访问多个系统时免重复输入身份信息。
3. 接收各系统不同的权限目录，按部门维护角色与员工授权。
4. 业务系统执行受控操作前取得统一鉴权结论，权限变更最多 3 秒影响后续请求。
5. 支持早高峰登录与持续鉴权，并给出可复现的性能测试条件。
6. 通过两个模拟业务系统展示登录、授权、拒绝、撤权及故障处理。
7. 保留关键事件审计，以需求、DFD、模块和测试对应关系支持课程验收。

2.2 运行环境

管理后台、统一登录页和模拟业务系统通过当前主流桌面版 Chrome、Edge 访问，不要求移动端适配。系统先在本机开发和演示。

普通员工只能使用认证入口和所获授权的外部系统。最高管理员与部门管理员额外拥有后台入口。平台管理员身份不会自动赋予外部系统业务角色。

具体技术结构及本地部署方式见配套分析与设计指南。

2.3 条件与限制

2.3.1 初始化资料与处理口径

来源	复核结果	初始化处理
员工表	10,000 人；用户名和手机号各有 10,000 个唯一、非空值；总公司 190 人，9 个分公司各 1,090 人	保留全部员工。岗位名称不自动产生平台管理员身份或业务授权。
部门表	111 个组织节点，包括 10 个公司、101 个末级部门	平台按公司和部门两层展示；保留分公司属于总公司的来源说明，不增加第三层部门。
员工组织归属	9 个分公司各有 6 人以公司节点填入“部门”，共 54 人；其余 9,946 人可对应末级部门	54 人保留公司直属、部门待确认状态，由最高管理员维护。明确部门前可认证，不能任命为部门管理员或分配部门角色。不自动归入同名或任意部门。
权限表	18 个系统名称、359 条功能点记录，其中“系统管理后台”21 条，外部系统338条	“系统管理后台”对应本平台，保留 17 个外部系统；功能点数量不等于拆分后的权限项数量。
五类岗位列	系统管理员、公司领导、部门经理、项目经理、普通员工	每个外部系统生成五类全局模板，名称不决定平台管理身份。

部门名称在不同公司可能重复，匹配时使用公司与部门完整归属。员工表中的部门简称与部门表中的“分公司名-部门名”按所属公司对应。

初始系统包括 OA 协同办公系统、企业即时通讯系统、企业知识库管理系统、人力资源管理系统、财务管理系统、工程项目管理系统（PMIS）、招投标管理系统、物资设备管理系统、移动巡检 APP、工地 AI 视频监控系统、GIS 地下管线管理系统、企业档案管理系

统、车辆管理系统、企业宣传平台、安全生产管理系统、合同全生命周期管理系统、成本管控系统。

权限单元格按斜杠拆分动作，`view`规范为“查看”。“无”及空值不授予权限。“全部”涵盖初始化时该功能点已列出的具体动作；若仅出现“全部”而没有具体动作，该功能点标记待目录确认，不能将“全部”当作可执行动作。外部系统后续上报的完整目录是其动作定义依据。

“查看本人”“编辑本人”保留操作含义及“本人”范围说明，由外部系统限制实际业务记录。平台允许操作的判断不替代这项数据范围校验。

2.3.2 管理与授权规则

1. 公司、部门、员工和系统可停用。组织有有效关联对象时，先处理关联数据再停用；有历史审计的数据不物理删除。
2. 一个部门可使用多个系统，一个系统可供多个部门使用，均可暂未配置。只有最高管理员能改变这项范围。
3. 固定平台角色为最高管理员、部门管理员。最高管理员人数不限，每部门可有多名部门管理员。首个最高管理员由课程初始化配置，后续任命走管理用例；至少保留一名有效最高管理员。
4. 部门管理员所属部门同时是其管理范围；公司直属员工仅由最高管理员维护。最高管理员可代办任意部门操作。
5. 模板和部门角色只属于一个系统。模板复制后独立维护，模板后续变更不覆盖部门角色。
6. 每名员工在每个系统最多有一个未撤销角色分配；分配部门必须与员工当前部门相同。不能直接给员工配置单项权限。
7. 部门范围被移除、系统或角色停用时，现有配置可保留供查询，但不能产生有效权限；重新启用前明确提示是否恢复原有效配置。正式删除角色前先撤销分配。
8. 调动前撤销全部系统的角色分配，等待撤权生效，并取消原部门管理员身份。调动后无角色，不按名称或模板自动继承。

2.3.3 登录与外部系统责任

1. 员工使用用户名和手机号同时校验，无密码、短信验证码。登录信息仅在统一登录页提交，不通过外部系统页面收集。
2. 本期接入基线为浏览器跳转。已登记系统的后端验证登录结果，取得统一身份，再发起鉴权。
3. 统一会话固定有效期最多 8 小时，使用会话不延长绝对到期时间。到期、统一退出或员工停用后，最多 3 秒拒绝新的鉴权。
4. 登录成功只证明身份有效。无目标系统角色、无操作权限或目标系统停用时，拒绝访问相应业务功能。
5. 不主动创建或同步外部账号，不推送角色副本；外部系统可维护自己的业务记录和会话关联，但身份、有效授权以平台为准。

6. OA 审批及线下授权申请流程由平台外部完成，管理员收到通知后配置权限。平台不处理审批。
7. “网关”在本项目中指统一认证和鉴权入口，业务请求及业务数据不由平台代理转发。

2.3.4 课程限制

本项目用于 OOAD 课程分析、设计与开发演示。保留会话校验、系统身份校验、范围隔离和拒绝越权等基本约束；用户名与手机号匹配不能提供生产系统所需的身份安全保证。

本期不要求密码策略、短信认证、多因素认证、多活容灾、工业级监控、生产合规及备份恢复。性能目标需实际测试，不能以课程 Demo 为由略过正确性验证。

3 数据描述

3.1 领域模型

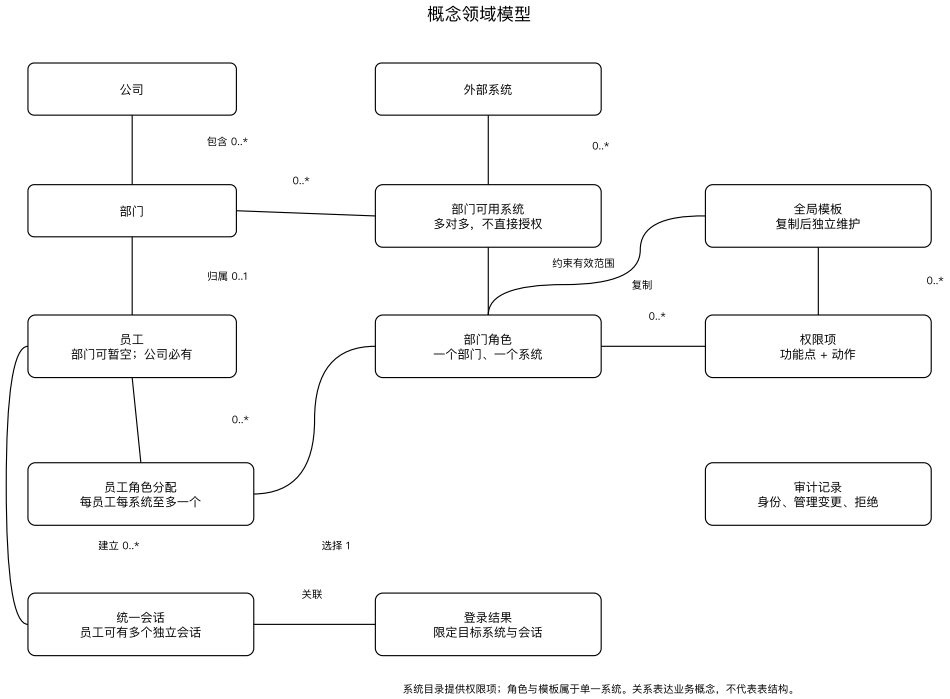


图 3-1 概念领域模型

公司拥有部门和员工。员工通常属于一个部门，54 名公司直属员工允许部门暂空。部门与系统的可用关系是多对多。部门角色由一个部门拥有，并使用一个系统的有效权限项；员工在各系统分别取得至多一个角色。

统一会话属于员工，登录结果与目标系统及该会话关联。鉴权读取身份状态、系统状态、部门可用范围、角色分配和有效权限。审计记录保存认证、管理变更及鉴权拒绝等事

件。

图中的概念及关联不表示数据库表或持久化结构。

3.2 上下文数据流

上下文数据流图

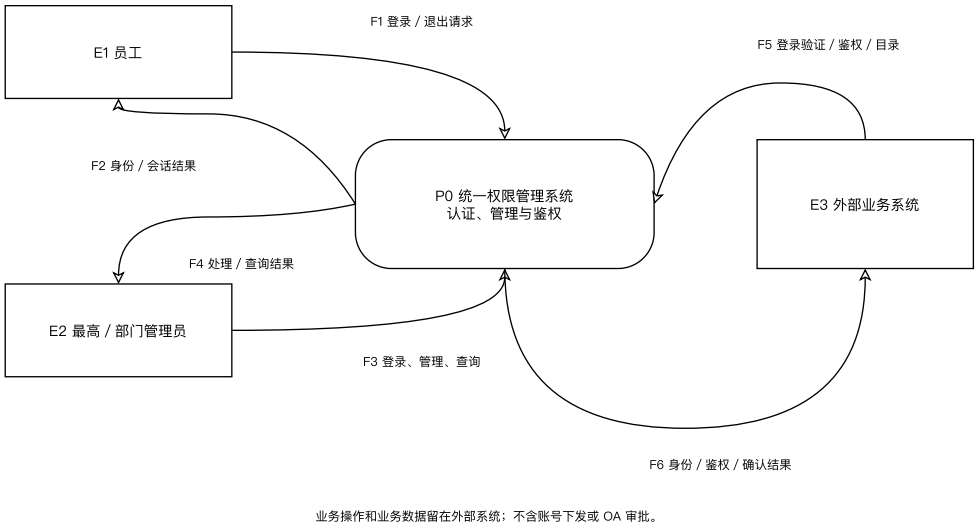


图 3-2 上下文数据流图

流编号	平台边界信息流
F1 / F2	员工提交登录与退出请求，取得认证结果和会话状态。
F3 / F4	管理员提交后台登录、管理变更和查询，取得处理结果及审计查询结果。
F5 / F6	外部系统提交登录接入、登录结果验证、鉴权请求和目录变更，取得身份、鉴权及目录确认结果。

员工浏览器的跳转由登录过程连接两个系统；业务操作的原始数据仍停留在外部业务系统。图中不绘制 OA 审批或账号下发。

3.3 一级数据流

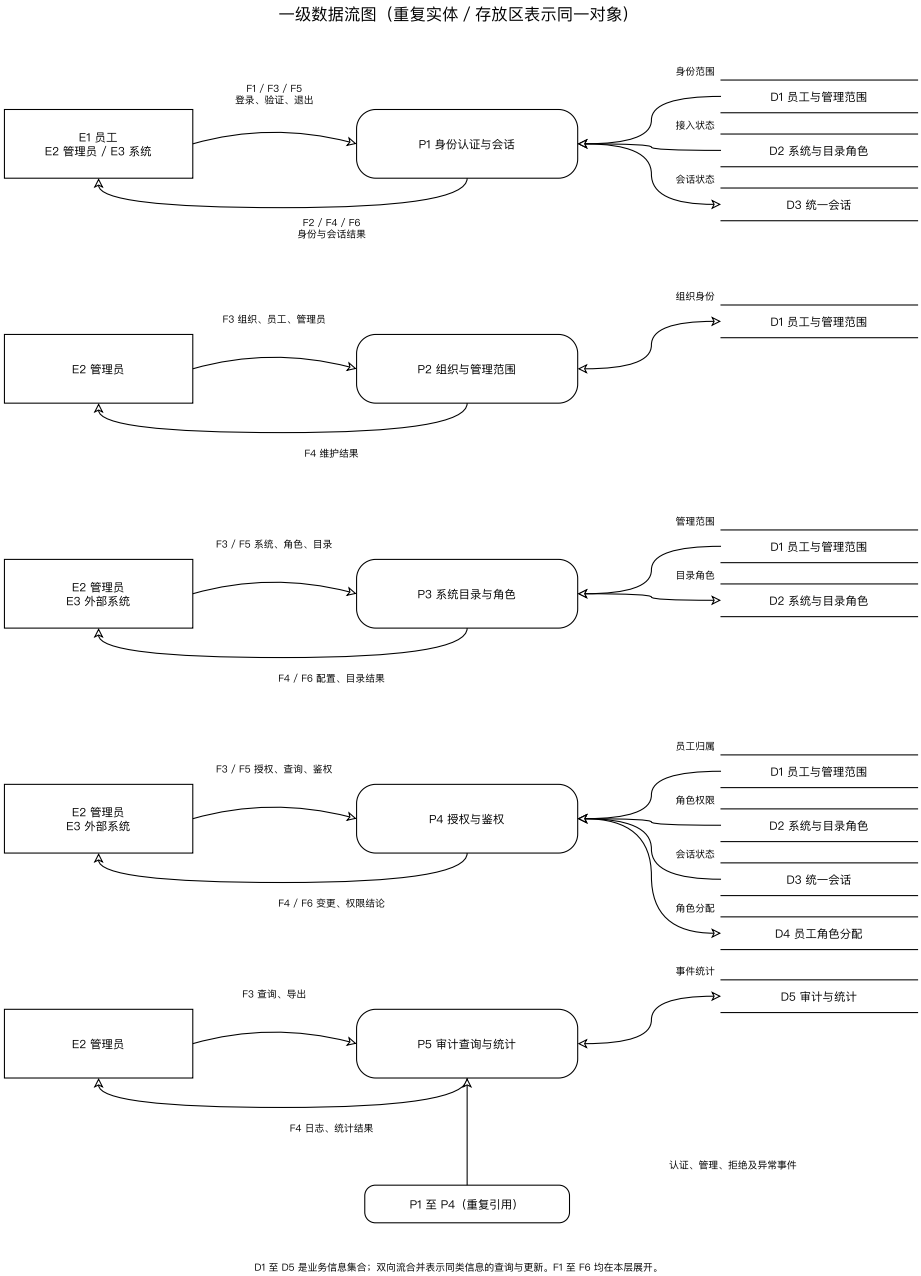


图 3-3 一级数据流图

处理	责任	信息集合
P1 身份认证与会话	员工和管理员身份校验、跳转结果、会话复用、到期与退出	D1 员工与管理范围、D2 系统与目录角色、D3 统一会话
P2 组织与管理范围	公司、部门、员工及管理员身份维护	D1 员工与管理范围

处理	责任	信息集合
P3 系统目录与角色	系统接入、部门可用系统、权限目录、模板和部门角色	D2 系统与目录角色
P4 授权与鉴权	角色分配、撤销、有效权限查询、运行时操作判断	D1、D2、D3、D4 员工角色分配
P5 审计查询与统计	接收事件，按范围查询导出，统计运行结果	D5 审计与统计

D1 至 D5 表示业务信息集合。信息集合之间不直接传递数据，由处理读取或改变。

F1、F2 在 P1 展开；F3、F4 按目的进入 P1 至 P5；F5、F6 在 P1、P3、P4 展开。一级图中的子流共同覆盖上下文图的全部边界信息。

3.4 关键二级数据流

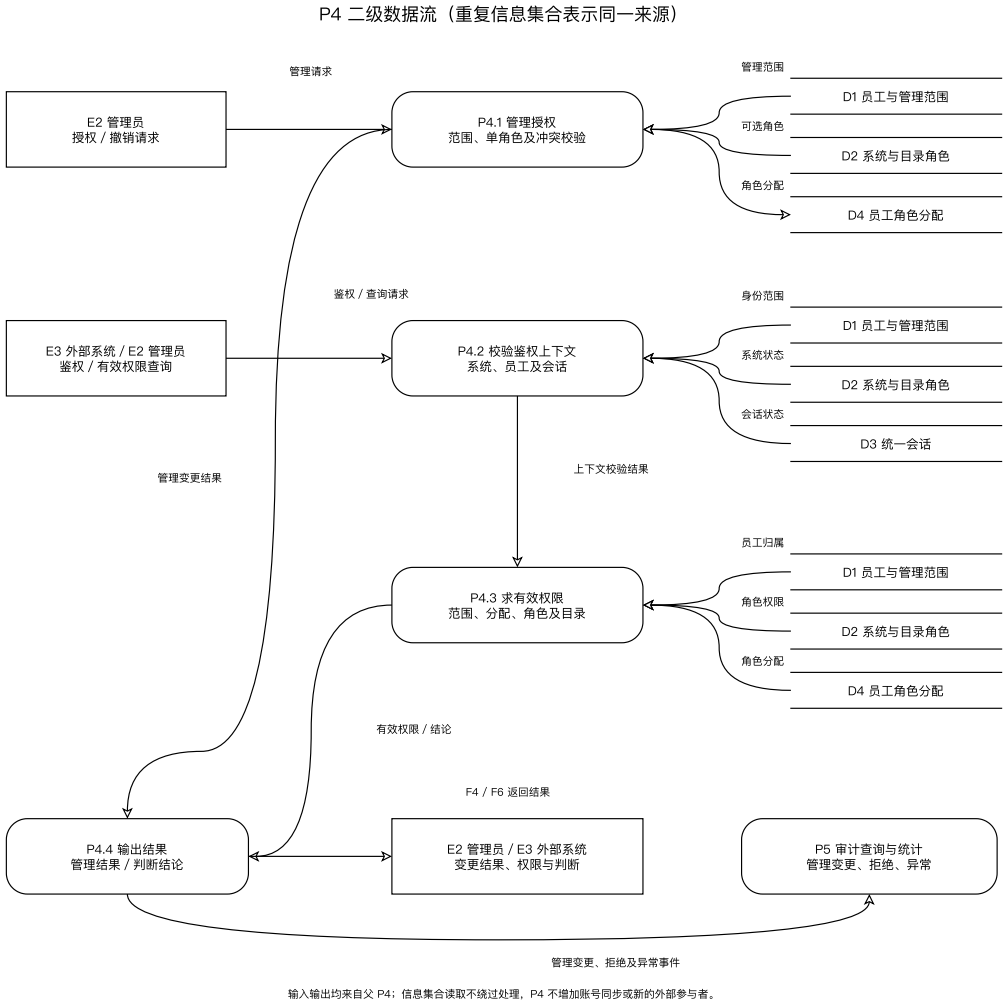


图 3-4 P4 授权与鉴权二级数据流图

P4 分解为 P4.1 管理授权、P4.2 校验鉴权上下文、P4.3 求有效权限、P4.4 输出判断与变更结果。P4.1 改变 D4；P4.2 读取员工、系统和会话状态并输出校验结果；P4.3 对无效上下文直接生成拒绝结论，对有效上下文综合部门范围、角色及目录；P4.4 返回结论并交给 P5 记录拒绝、异常或管理变更。

管理查询校验操作者会话与管理范围，可以查询尚未登录的员工；运行时鉴权校验目标员工的当前统一会话。查询有效角色不要求目标员工先登录。

父处理的管理请求、运行时鉴权请求、查询请求和相应结果均出现在子图边界。子处理不增加新的外部参与者。DFD 表达信息处理；各场景时间顺序见第 4.2 节，总流程见第 4.3 节。

3.5 数据库设计

3.5.1 概念 ER

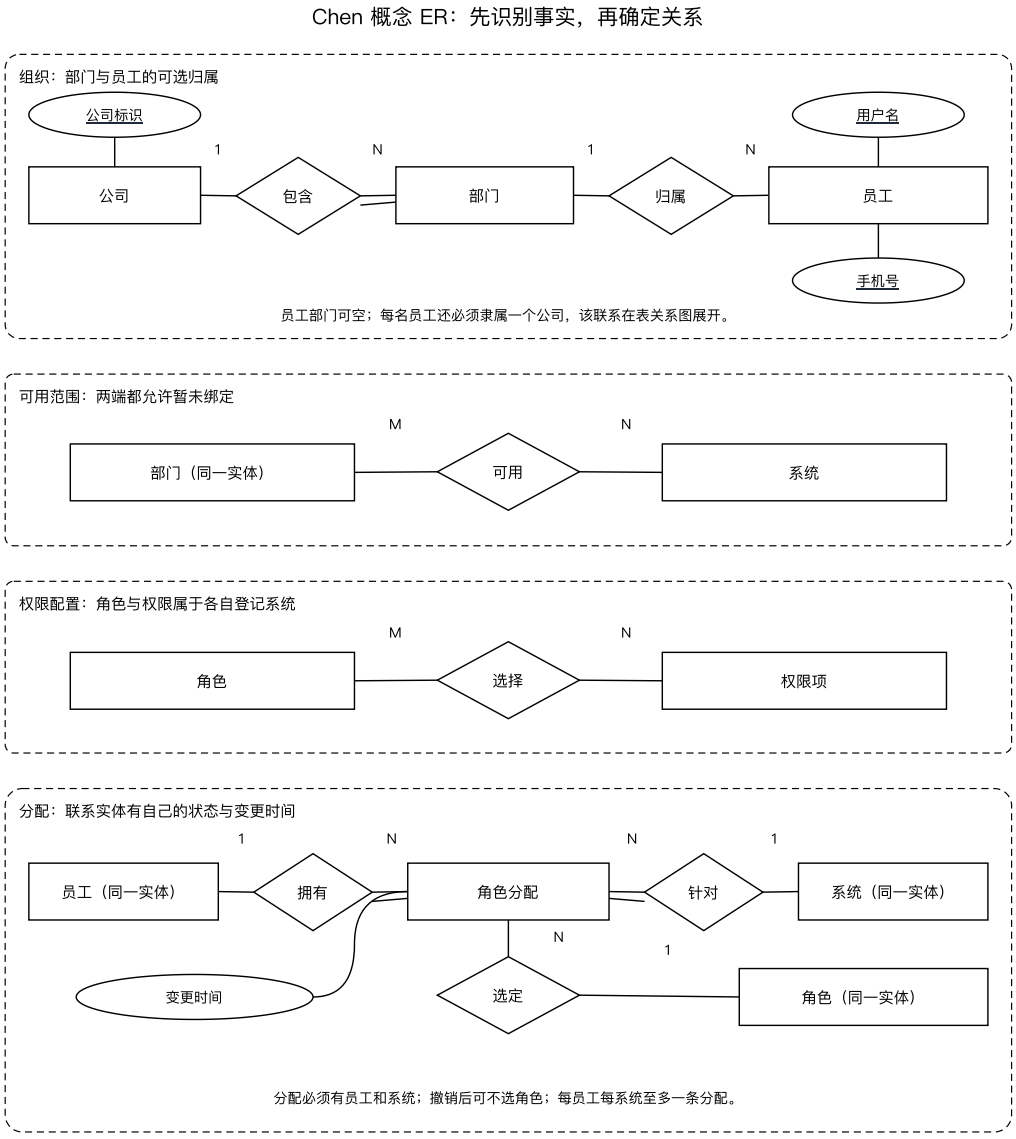
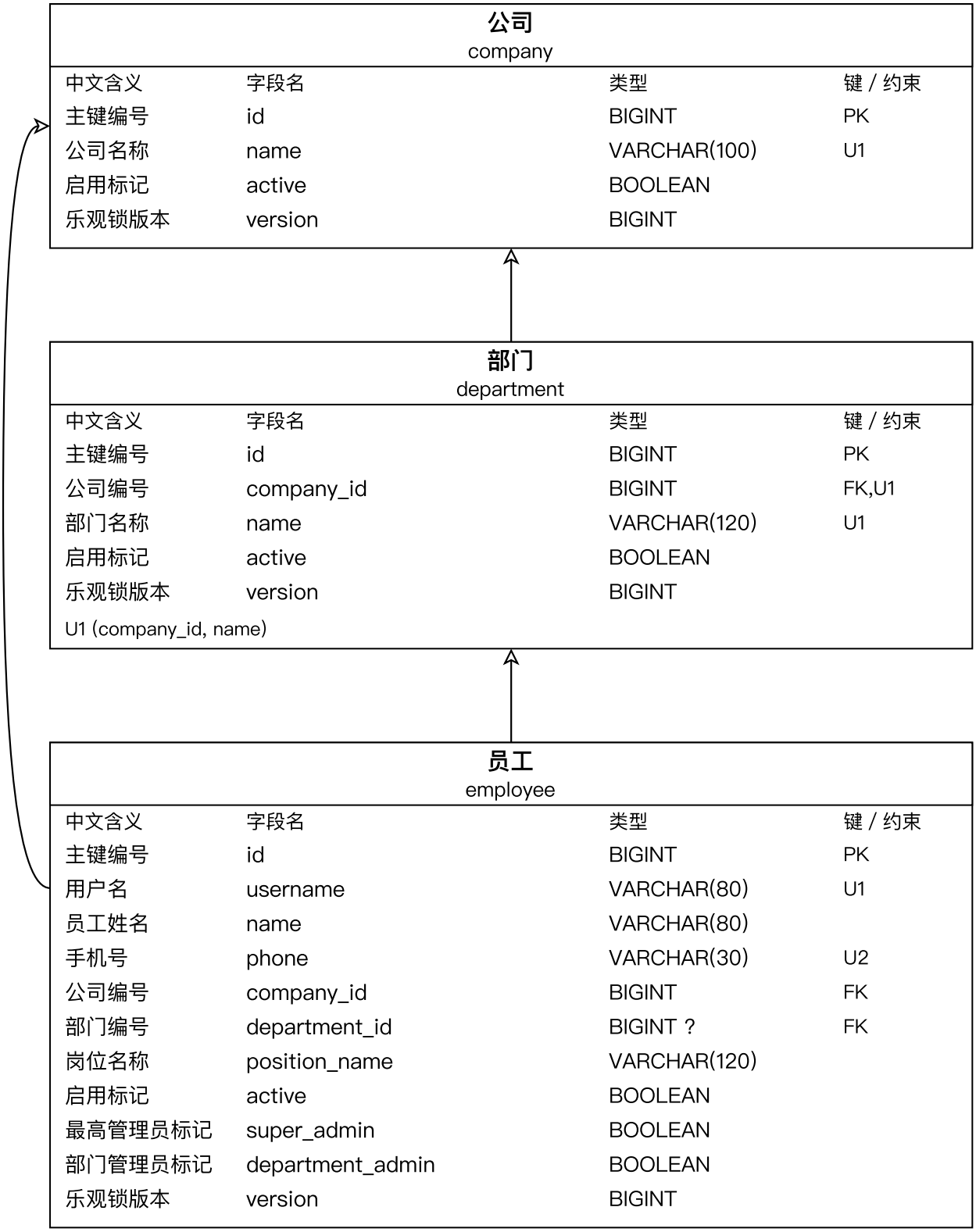


图 3-5 核心业务概念 ER 图

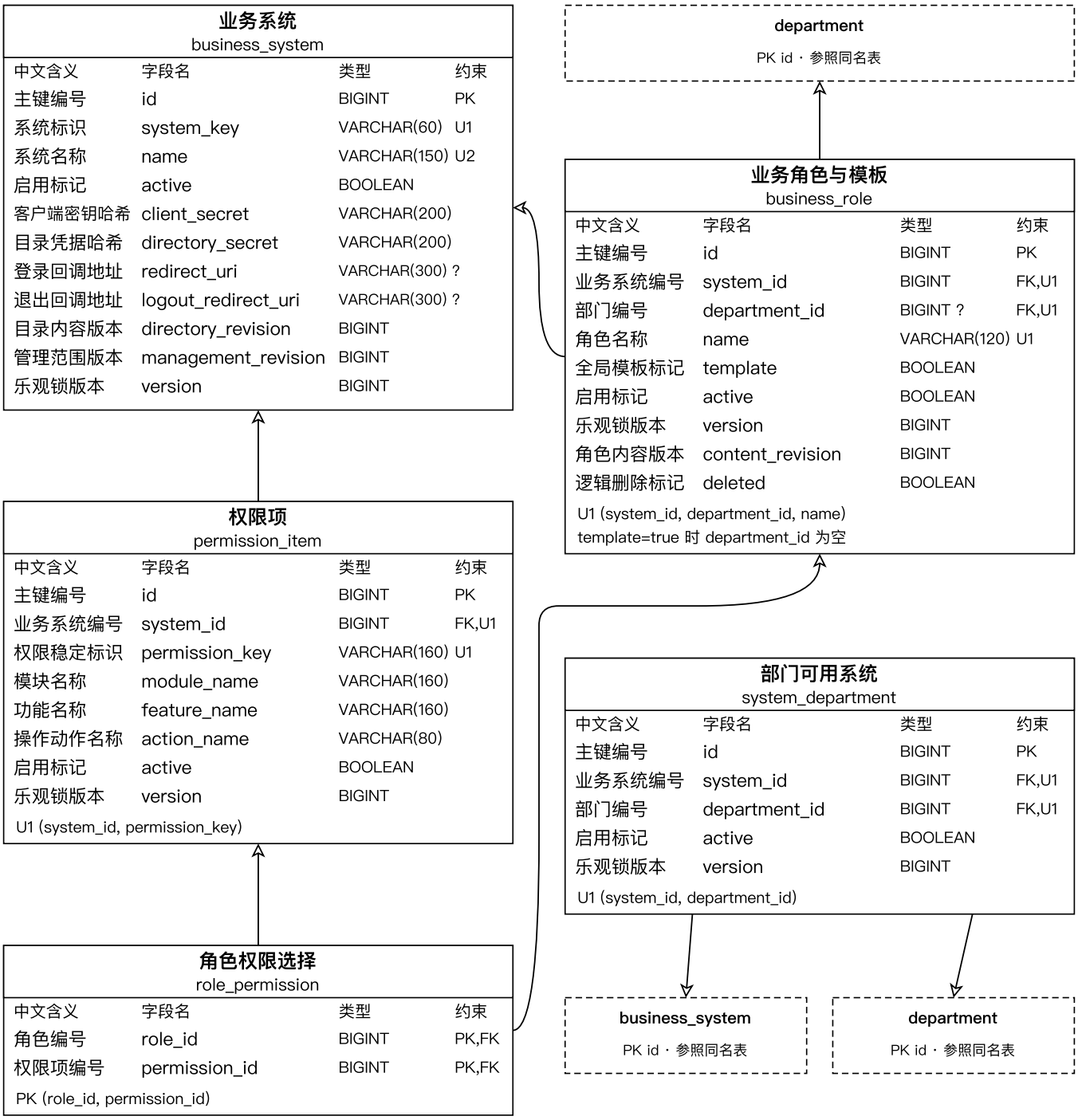
实体为公司、部门、员工、系统、角色和权限。部门与系统、角色与权限均为多对多；员工角色分配单独保存，以表达每员工每系统单角色及撤销状态。Chen 图中矩形为实体、菱形为联系、椭圆为属性，双线表示全参与，1 / N / M 表示最大基数。

3.5.2 逻辑关系



PK 主键；FK 实际外键；U1/U2 同表内分别编号的唯一键；? 可空。
实线箭头：引用表指向被引用表；REF 仅由应用维护，无物理外键。
employee.department_id 可空；公司与部门归属一致由应用校验。

图 3-6(a) 数据库表关系：组织与员工



PK 主键；FK 实际外键；U1/U2 同表内分别编号的唯一键；？可空。
实线箭头：引用表指向被引用表；REF 仅由应用维护，无物理外键。
虚线边框为同名表参照；同系统选权、模板形态及模板重名由应用检查。

图 3-6(b) 数据库表关系：系统、部门范围、目录与角色



PK 主键；FK 实际外键；U1/U2 同表内分别编号的唯一键；? 可空。
实线箭头：引用表指向被引用表；REF 仅由应用维护，无物理外键。
审计与批量的 REF 不建外键；初始化标记无业务关联。

图 3-6(c) 数据库表关系：分配、批量、审计与初始化

图 3-6 按竖向页面分三页展示当前 13 张表的全部 90 个字段，每个字段依次列出中文含义、字段名、类型和键约束，类型依据 Flyway V1 至 V4；BOOLEAN 为迁移使用的 MySQL 布尔类型别名。PK 为主键，FK 为实际外键，U1 / U2 为各表内分别编号的唯一键，同号字段共同组成一个唯一键，? 表示可空；未标 ? 的字段均不可空。实线箭头从引用表指向被引用表；REF 表示仅由应用维护的编号引用，不是外键；虚线边框为跨页参照，不增加表数量。

例如，role_assignment 的 employee_id 与 system_id 同标 U1，表示二者组合唯一；role_id 标 FK 且可空，撤权后仍保留分配行。审计中的 actor_id 标 REF，因此不应把历史操作者引用误读为物理外键。统一会话、OIDC 授权与令牌在内存中，未建立认证数据库表，进程重启后失效。

表／模块	主要事实与字段	键、关系与约束
company、department（M2）	公司名称、部门名称、company_id、active、version	名称按公司或全局范围唯一；部门必须关联一个公司，不设下级部门
employee（M2）	username、phone、company_id、department_id、两个管理员标记、active、version	用户名和手机号分别唯一；公司必填、部门可空。公司和部门有外键，两者归属一致由应用校验
business_system（M3）	system_key、凭据哈希、回调、directory_revision、management_revision、version	系统标识和名称分别唯一；凭据不返回到普通查询；三类版本分别表示目录内容、管理范围及持久化并发版本
system_department（M3）	system_id、department_id、active、version	系统与部门配对唯一；两端为实际外键，实现多对多可用范围
permission_item（M4）	system_id、permission_key、模块 / 功能 / 动作、active	权限 key 在系统内唯一；系统为实际外键；名称变更不改变稳定 key
business_role（M4）	system_id、department_id、name、template、active、deleted、content_revision、version	模板无部门、不可直接分配；部门角色必须属于部门。组合唯一键含可空部门，模板重名另由治理锁内检查
role_permission（M4）	role_id、permission_id	两列为复合主键及外键；同系统、有效权限由应用校验
role_assignment（M5）	employee_id、system_id、role_id、revoked、changed_at、version	员工与系统配对唯一；三个编号有外键。撤销保留该行，角色置空；归属一致由应用检查
batch_job、batch_item（M5）	操作者、request_key、共同意图、员工旧版本、状态及结果	操作者与请求键唯一；任务与员工唯一。只有明细的 job_id 建实际外键，其他关联由应用维护
audit_event（M6）	时间、操作者、事件时部门与原部门、系统、类型、对象、结果、详情	历史编号不建当前事实外键；保留事件时范围，不能用员工当前部门改写历史

表／模块	主要事实与字段	键、关系与约束
seed_marker（初始化）	marker_key、applied_at	marker_key 主键；记录已成功提交的初始化叠加

3.5.3 索引与完整性

索引／约束	用途与边界
employee(department_id, active)	本部门有效员工筛选；身份唯一索引另支持登录定位
role_assignment(employee_id, system_id) 唯一键	保证每员工每系统至多一行；其员工前缀支持全部分配查询
role_assignment(role_id, revoked)	查询角色影响及删除前分配检查
audit_event(department_id, occurred_at)、(occurred_at)	范围内及全局时间筛选；其他筛选不承诺都有专用索引
role_permission 复合主键与各外键	避免重复权限选择并保证引用存在；角色、权限同系统仍由应用保证

角色权限和部门可用系统分别使用关联表，不保存逗号分隔编号。角色名称只存角色表，避免每条权限选择重复更新。员工公司在部门可空时仍须保存；有部门时由保存与调动共同保证一致。审计中的部门是历史事实，不随当前资料更新。

结构由 Flyway V1 至 V4 演进，JPA 使用 validate；V2 增加角色内容版本，V3 增加批量幂等键，V4 增加角色逻辑删除。实际约束不包含 revoked 与 role_id 组合 CHECK，也未用复合外键保证分配同系统，须保留应用检查。迁移源位于 platform/src/main/resources/db/migration/。

3.5.4 事务与并发约束

管理写入先取固定总公司行的治理锁，再按员工、系统、角色顺序锁定相关事实。该粗锁简化竞态控制，同时限制管理写入吞吐。唯一键防重复行，expectedVersion 检测旧页面意图，JPA @Version 防保存覆盖，事务保证一组状态共同提交，四者各有职责。

授权替换与成功审计同事务；员工停用的员工状态、撤权与审计同事务；提交后才撤销内存会话和失效缓存。批量任务按员工逐项事务，失败不回滚其他成功项。具体过程见第 4.2 节对应场景和第 4.5 节。

4 功能需求

4.1 功能划分

参与者	使用方式
普通员工	经外部系统使用统一登录、会话复用及统一退出；不进入管理后台。
最高管理员	全局管理、模板维护、部门可用系统配置，及部门操作代办。
部门管理员	本部门员工、部门角色、授权和范围内日志管理。
外部系统	发起登录接入，验证登录结果，执行受控操作前鉴权，上报权限目录。

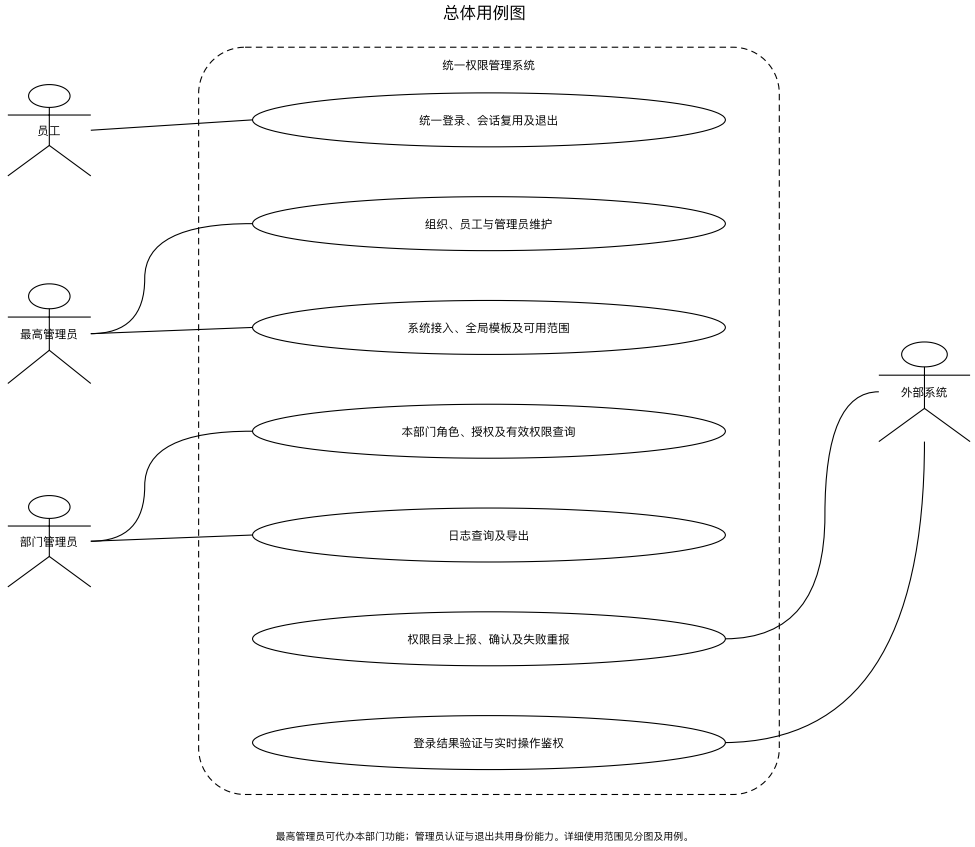


图 4-1 总体用例图

4.2 功能描述

下列表格沿用参考 PDF 的用例信息项目，并增加前置、后置条件。“信息”描述业务概念，不规定请求字段。每个用例之后给出场景流程及对应方法、URL 和功能；框架协议端点标为框架能力，避免把它们误认为项目 Controller。URL 均为路径，前缀采用当前部署入口。

4.2.1 管理员登录

用例编号： UPMS-REQ-AUTH-001	用例名称： 管理员登录
级别： 用户目标	
包： 身份认证与会话	
参与者： 最高管理员、部门管理员	
描述： 管理员通过统一身份校验进入对应范围的后台。	
触发事件： 管理员打开后台并提交登录资料，或携带已有统一会话访问后台。	
前置条件： 员工有效，已具有有效管理员身份。	
主成功场景：	**信息**
1. 校验用户名、手机号属于同一员工，或验证已有会话。	提交的登录资料及已有会话
2. 校验管理员身份及范围。	员工的管理员身份与管理范围
3. 建立或复用统一会话，显示对应后台功能。	统一会话和允许访问的后台范围
扩展场景：	**处理及信息**
登录资料缺失、不匹配或员工停用	拒绝认证，使用不暴露账号是否存在的提示。
员工有效但没有后台管理员身份	拒绝进入管理后台。
管理员身份已取消	后续后台访问按新身份状态拒绝。
后置条件： 成功或失败写入认证审计；无外部业务角色自动产生。	
其他： 失败提示不暴露用户名或手机号是否存在；后台退出执行 AUTH-004。	

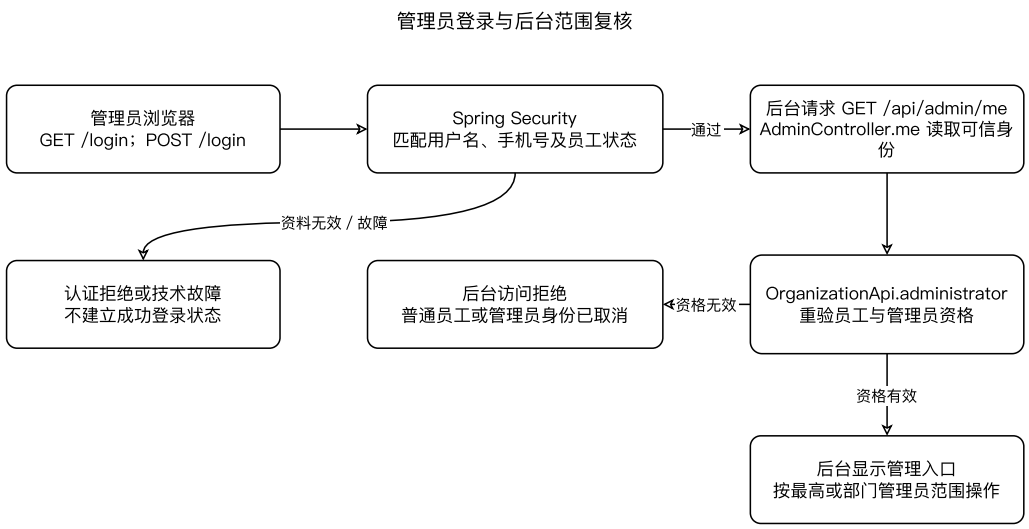


图 4-2 管理员登录核验场景流程图

备注：认证通过后仍须通过管理员资格检查；普通员工在“后台访问拒绝”处分流，不能沿成功路径继续。

图中处理／实际方法	调用说明 URL	功能
LoginController.csrf；框架表单认证	GET /api/csrf、POST /login	取得 CSRF 保护资料并提交员工登录表单
AdminController.me	GET /api/admin/me	使用服务端会话判断平台管理员身份及范围

4.2.2 员工统一登录

用例编号： UPMS-REQ-AUTH-002	用例名称： 员工经业务系统统一登录
级别： 用户目标	
包： 身份认证与会话	
参与者： 员工、外部系统	
描述： 员工跳转至统一登录页，业务系统验证登录结果后识别员工。	
触发事件： 未登录员工选择业务系统的统一登录入口。	
前置条件： 目标系统已登记、有效，返回目标已认可；员工资料存在。	
主成功场景：	**信息**
1. 业务系统发起登录跳转。	发起系统和认可的返回目标
2. 平台显示目标系统及统一登录页。	目标系统资料及统一登录页
3. 员工提交用户名与手机号。	员工提交的用户名与手机号
4. 校验员工有效并建立会话。	员工有效状态和新建会话
5. 浏览器返回认可的业务系统。	浏览器返回位置及授权结果
6. 业务系统后端验证登录结果，取得员工统一身份。	单次登录结果及业务系统验证出的身份
扩展场景：	**处理及信息**
系统未登记、已停用或返回目标未获认可	拒绝发起登录并说明接入不可用。
员工资料不匹配或员工已停用	拒绝认证，不签发登录结果。
登录结果过期、篡改、跨系统使用或重复兑换	业务系统不得建立已登录会话。
网络或认证服务发生技术故障	显示可重试提示，不将故障记为认证成功。
后置条件： 认证事件可追溯；业务系统只得到经验证的身份，访问权限仍需鉴权。	
其他： 外部系统不收集用户名和手机号；本期不要求直接提交登录凭据的接入模式。	

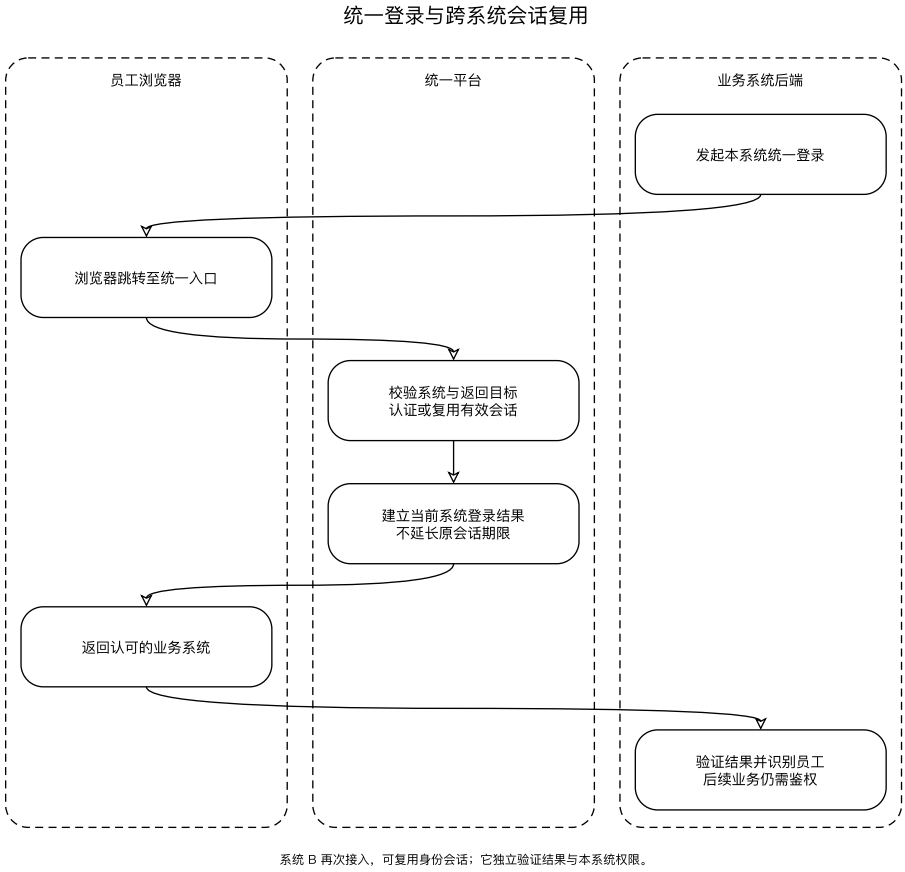


图 4-3 员工统一登录与结果兑换场景流程图

备注：浏览器完成跳转，业务系统后端完成兑换。身份凭据只交给平台；取得身份之后，受控操作继续走 AUTHZ-001。

图中处理／实际方法	调用说明 URL	功能
框架发现与授权端点；DemoSecurity.security 配置接入	GET /.well-known/openid-configuration、GET /oauth2/authorize	取得 OIDC 配置并发起授权码登录
框架表单认证与令牌兑换；AtomicCodeExchange.authenticate 补充并发保护	POST /login、POST /oauth2/token	建立员工会话并由目标系统后端兑换一次性登录结果

4.2.3 跨系统会话复用

用例编号： UPMS-REQ-AUTH-003	用例名称： 复用统一会话进入其他系统
级别： 用户目标	
包： 身份认证与会话	
参与者： 员工、外部系统	
描述： 同一浏览器已有有效统一会话时，进入另一个系统免重复输入资料。	
触发事件： 员工从系统 A 进入系统 B 的统一登录入口。	
前置条件： 系统 B 有效，统一会话有效。	
主成功场景：	**信息**
1. B 发起跳转。	系统 B 的登录请求
2. 平台验证统一会话及员工状态。	统一会话状态和员工状态
3. 为 B 产生新的登录结果。	仅供系统 B 使用的登录结果
4. B 后端验证并识别同一员工。	系统 B 验证出的员工身份
5. B 独立判断自己的业务访问权限。	系统 B 的当前业务权限结论
扩展场景：	**处理及信息**
统一会话过期、退出或员工停用	要求重新登录。
身份已识别但系统 B 没有对应角色	登录身份可确认，B 的受控操作仍拒绝。
后置条件： 原会话到期时间不延长，不复用 A 的登录结果。	
其他： 浏览器间、设备间不要求共享会话。	

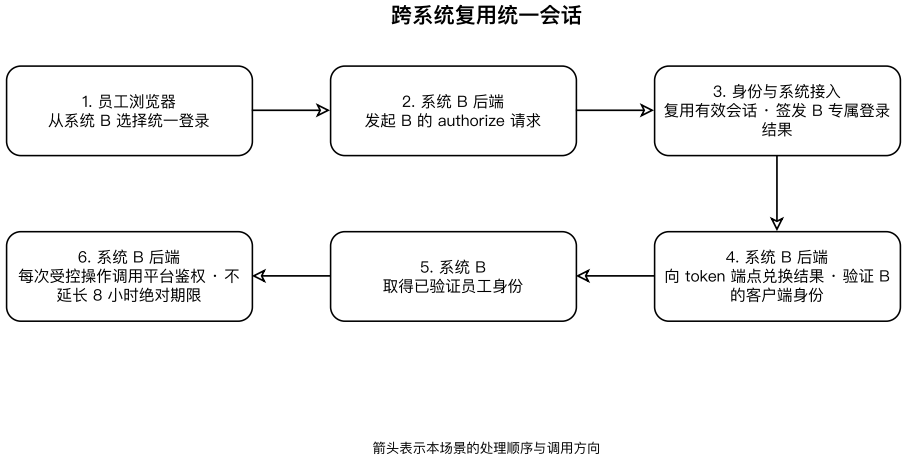


图 4-4 跨系统会话复用场景流程图

备注：系统 B 重新取得自己的授权码并兑换；免重复填写资料来自统一会话复用，A 的登录结果不会直接交给 B。

图中处理／实际方法	调用说明 URL	功能
框架授权与令牌端点；同一会话为 B 重新授权	GET /oauth2/authorize、POST /oauth2/token	复用平台会话，但签发及兑换 B 专属授权码

4.2.4 统一退出

用例编号： UPMS-REQ-AUTH-004	用例名称： 结束当前统一会话
级别： 用户目标	
包： 身份认证与会话	
参与者： 员工、管理员、外部系统	
描述： 在任一入口退出，使同一统一会话的所有系统后续请求失效。	
触发事件： 用户在后台或业务系统选择统一退出。	
前置条件： 存在当前会话；业务系统退出请求来源可信。	
主成功场景：	**信息**
1. 平台确认当前会话并标记失效。	当前统一会话和退出来源
2. 返回退出结果。	统一会话失效状态及退出结果
3. 外部系统清理本地会话关联。	各应用本地会话与清理状态
4. 最多 3 秒后，其他系统不得继续通过该会话鉴权。	后续鉴权采用的会话有效状态
扩展场景：	**处理及信息**
同一会话重复退出	返回已退出状态，不影响其他会话。
统一退出服务不可用	本地会话可清理，但必须提示全局退出未确认；受控操作拒绝。
后置条件： 退出记录可查询；其他独立浏览器会话不受影响。	
其他： 已显示页面不要求自动关闭，但后续受控操作必须重新登录。	

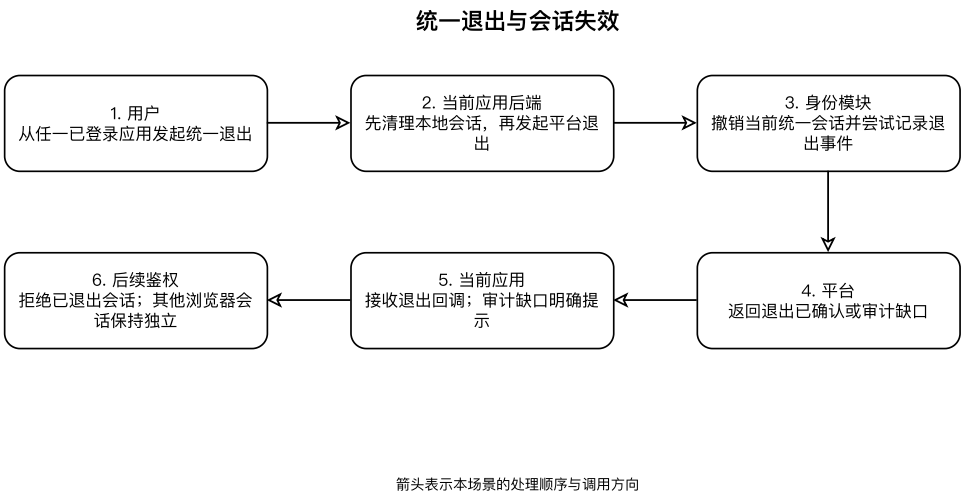


图 4-5 统一退出场景流程图

备注：模拟系统先清理本地会话，再经框架发起统一退出；退出审计失败会提示缺口，已失效的统一会话不会恢复。后台直接执行平台退出。

图中处理／实际方法	调用说明 URL	功能
框架 LogoutFilter；DemoSecurity.security 配置 RP 退出	POST /logout	清理发起应用本地会话并启动统一退出
框架 OIDC 退出端点；UnifiedOidcLogoutHandler.logout	GET /connect/logout	使统一会话失效并按已登记地址返回

4.2.5 组织维护

用例编号： UPMS-REQ-ORG-001	用例名称： 维护公司和部门
级别： 用户目标	
包： 组织管理	
参与者： 最高管理员	
描述： 查询、新增、修改、停用公司与部门。	
触发事件： 最高管理员提交组织变更。	
前置条件： 有效最高管理员会话。	
主成功场景：	**信息**
1. 展示公司、部门及状态。	公司、部门及当前状态
2. 提交变更。	管理员提交的组织变更
3. 校验公司归属、部门层级及同公司内名称。	公司归属、层级、名称及版本检查结果
4. 保存并记录审计。	保存后的组织事实和审计事件
扩展场景：	**处理及信息**
部门存在下级部门、名称冲突或层级不符合约束	拒绝保存并指出待修正的组织关系。
停用对象仍有关联员工、管理员或系统范围	要求先处理关联关系，不显示停用完成。
后置条件： 组织资料一致；历史审计保留。	
其他： 不以部门名称跨公司合并对象。	

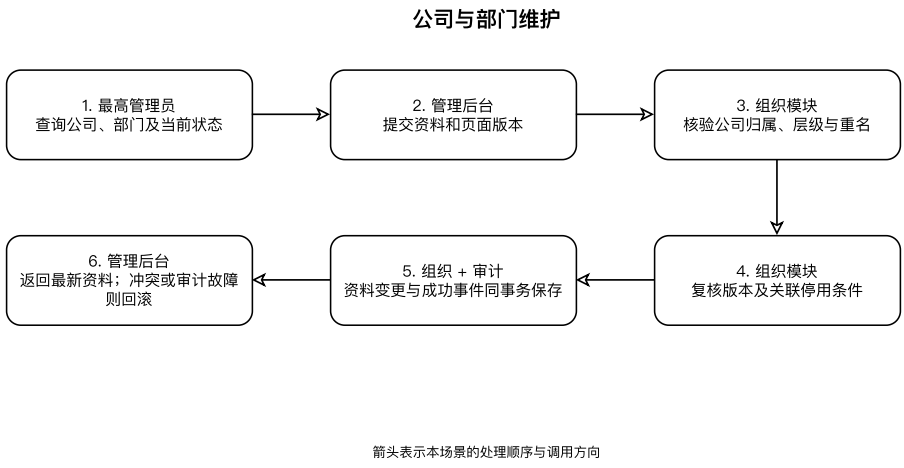


图 4-6 公司与部门维护场景流程图

备注：页面携带的版本只表达管理员看到的状态，服务端保存前仍检查归属和关联；成功变更与审计一起提交。

图中处理／实际方法	调用说明 URL	功能
AdminController.companies、company	GET /api/admin/companies、POST /api/admin/companies	查询及保存公司信息
AdminController.departments、department	GET /api/admin/departments、POST /api/admin/departments	查询及保存部门信息；版本和关联检查由服务端执行

4.2.6 员工维护

用例编号： UPMS-REQ-EMP-001	用例名称： 维护员工资料与状态
级别： 用户目标	
包： 员工管理	
参与者： 最高管理员、部门管理员	
描述： 维护授权对象及统一登录身份，部门管理员限本部门。	
触发事件： 管理员查询、提交资料或停用员工。	
前置条件： 有效管理员会话，对目标员工有管理范围。	
主成功场景：	**信息**
1. 按姓名、用户名、公司、部门或手机号筛选。	筛选条件和已校验的管理范围
2. 新增或修改资料，校验必填和唯一性。	员工资料、必填项和唯一性检查
3. 保存并审计。	保存后的员工资料及审计事件
4. 停用时撤销全部系统角色分配并使所有会话失效，最多 3 秒影响鉴权。	停用影响的角色分配、会话及生效期限
扩展场景：	**处理及信息**
用户名或手机号重复	拒绝资料保存并提示唯一性冲突。
批量目标中含其他部门员工	整批拒绝，不产生部分变更。
员工停用过程中的撤权或审计未能提交	停用失败，不显示为已完成。
部门变更针对已归属部门的员工	转到 EMP-002 调动流程，即使员工当前没有角色也要校验。
后置条件： 资料或状态更新；停用员工不能登录或通过鉴权。	
其他： 身份资料修改不推送外部账号。修改手机号不自动重新授予角色。重新启用不恢复停用时已撤销的分配。公司直属员工首次明确部门由最高管理员处理，不自动任命部门管理员。	

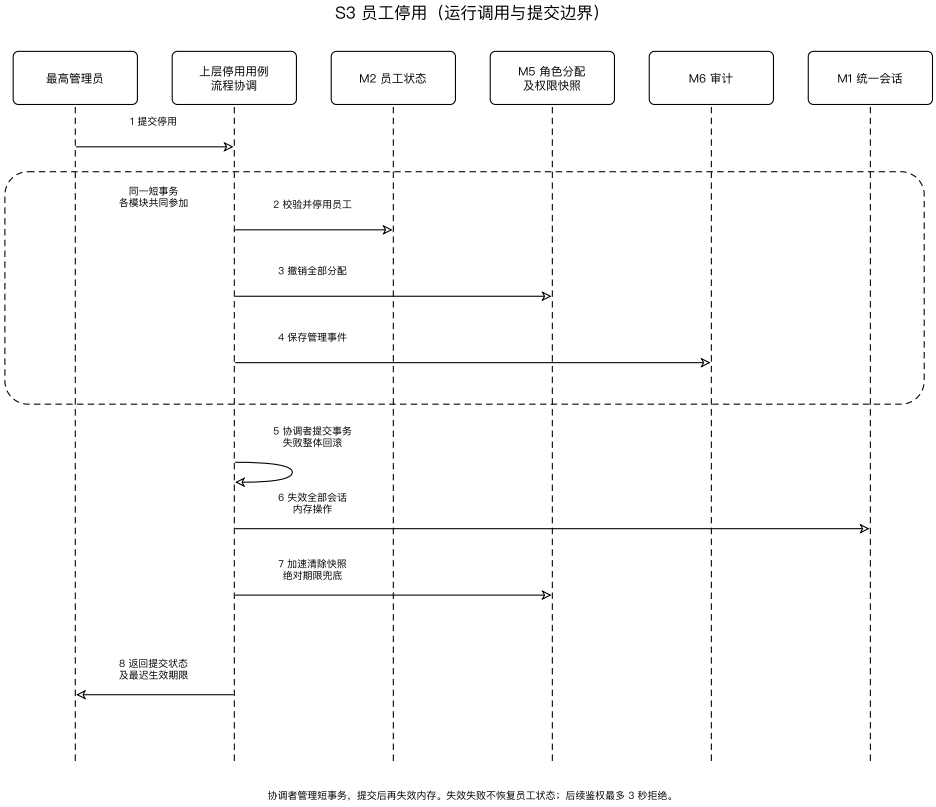


图 4-7 员工停用与跨模块收尾场景流程图

备注：图中展开员工停用分支。普通资料维护不需要撤权；停用时数据库事务包含状态、分配和审计，内存会话在提交后失效。

图中处理／实际方法	调用说明 URL	功能
AdminController.employees、employee	GET /api/admin/employees、GET /api/admin/employees/{id}	按已验证管理范围筛选、查看员工
AdminController.employee、state；停用转 EmployeeLifecycle.state	POST /api/admin/employees、POST /api/admin/employees/{id}/state	维护员工资料或停用；停用事务包括角色撤销和审计

4.2.7 跨部门调动

用例编号： UPMS-REQ-EMP-002	用例名称： 手工撤权后调动员工
级别： 用户目标	
包： 员工管理	
参与者： 原部门管理员、最高管理员、新部门管理员	
描述： 协作完成撤销旧授权、变更部门及重新授权。	
触发事件： 线下通知员工调动。	
前置条件： 目标部门有效；各操作者有相应范围。	
主成功场景：	**信息**
1. 原部门撤销全部系统角色，核对逐系统结果及撤权生效。	原部门员工的全部系统分配
2. 最高管理员校验无未撤销分配，取消原部门管理员身份（若有）。	撤权结果、原部门管理员身份及最高管理员校验
3. 修改部门。	新部门信息和部门修改结果
4. 新部门按获准系统重新选择角色并授权。	新部门管理员按范围重新建立的角色分配
扩展场景：	**处理及信息**
仍有未撤销分配或撤权未生效	禁止修改部门。
调动与新授权并发发生	检测到冲突后拒绝本次操作，要求刷新状态。
新部门尚未重新授权	员工保持无业务角色，不继承旧角色。
后置条件： 员工只按新部门范围授权；原部门失去管理权。	
其他： 最高管理员可代办原部门撤权；不自动继承旧角色，不自动成为新部门管理员。	

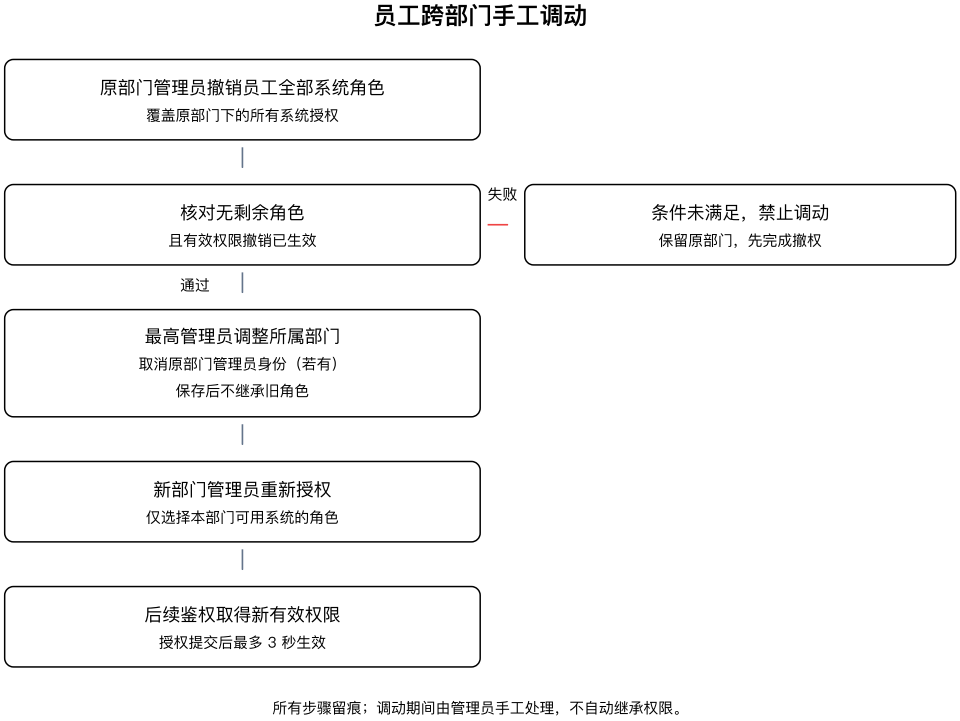


图 4-8 撤权后跨部门调动场景流程图

备注：原部门撤权、最高管理员调动、新部门重新授权是三次明确操作；存在未撤销分配或撤权等待窗口时停止调动。

图中处理／实际方法	调用说明 URL	功能
原部门：AdminController.assignment、batch	POST /api/admin/assignments 或 POST /api/admin/batches	逐系统撤销员工角色并检查结果
AdminController.transfer；EmployeeLifecycle.transfer	POST /api/admin/employees/{id}/transfer	撤权后核对并修改员工部门
新部门：AdminController.assignment、batch	POST /api/admin/assignments 或 POST /api/admin/batches	重新建立新部门角色授权

4.2.8 管理员任命

用例编号： UPMS-REQ-ADM-001	用例名称： 任命、取消管理员
级别： 用户目标	
包： 管理范围	
参与者： 最高管理员	
描述： 从有效员工中任命或取消固定平台管理身份。	
触发事件： 最高管理员确认身份变更。	
前置条件： 有效最高管理员会话；任命对象有效。	
主成功场景：	**信息**
1. 选员工及管理身份。	员工与待设置的平台管理身份
2. 任命部门管理员时确认其实际部门。	员工所属部门及任命资格
3. 保存身份与范围。	已保存的管理身份和范围
4. 后续后台访问最多 3 秒按新范围判断。	后续后台请求使用的新管理范围
扩展场景：	**处理及信息**
任命对象没有明确有效部门	拒绝任命为部门管理员。
操作将取消最后一名有效最高管理员	拒绝操作并保留现有管理能力。
最高管理员要取消本人身份	必须由另一名最高管理员执行。
后置条件： 任命和取消留痕，不改变外部业务角色。	
其他： 同时有多个身份时，最高管理员使用全局范围；平台角色定义不可编辑。	

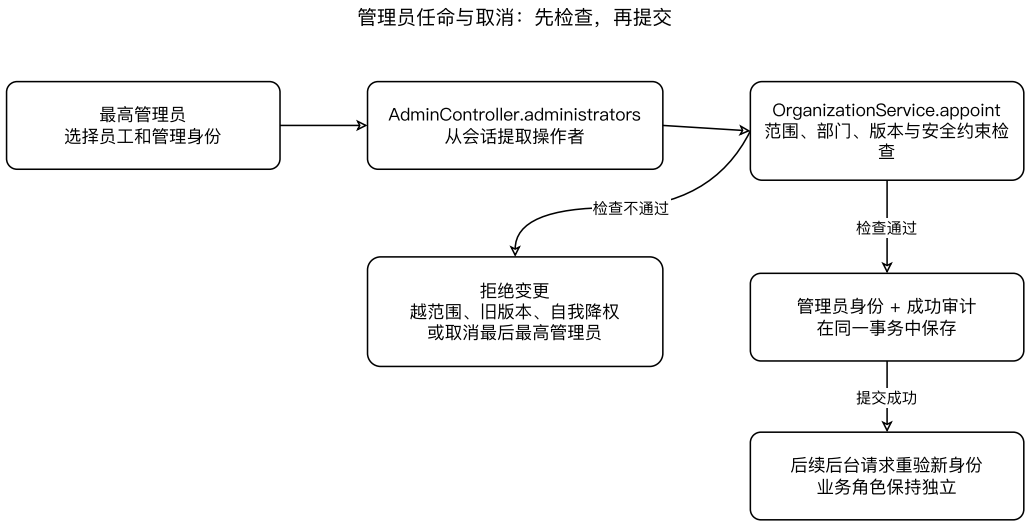


图 4-9 管理员身份任免场景流程图

备注：安全检查通过才进入保存分支；取消最后一名最高管理员等请求直接拒绝。平台管理身份和外部系统业务角色分别维护。

图中处理／实际方法	调用说明 URL	功能
AdminController.administrators	POST /api/admin/administrators	任命或取消固定平台管理身份；员工业务角色保持独立

4.2.9 系统及部门可用范围

用例编号： UPMS-REQ-SYS-001	用例名称： 维护系统接入与部门可用系统
级别： 用户目标	
包： 系统接入	
参与者： 最高管理员	
描述： 登记系统、认可返回目标、启停及维护多对多可用关系。	
触发事件： 最高管理员提交系统或范围变更。	
前置条件： 有效最高管理员会话；关联部门有效。	
主成功场景：	**信息**
1. 登记唯一系统标识、名称和业务接入信息。	系统标识、名称和接入资料
2. 配置可使用该系统的部门。	可使用该系统的部门集合
3. 显示受影响角色及员工数并确认。	受影响角色、员工和访问范围
4. 保存、审计，最多 3 秒影响登录接入与鉴权。	系统状态、部门关联及审计事件
扩展场景：	**处理及信息**
系统标识重复或系统未登记	拒绝保存或接入。
移除部门范围或停用系统会影响已有角色与员工	先展示影响；管理员确认后才保存变更。
重新启用含有旧配置的系统	提示保留配置可能恢复访问，并要求确认。
后置条件： 只有有效系统及获准部门可形成有效授权。	
其他： 删除关联不删除历史审计。模板或目录名称相同不合并系统。	

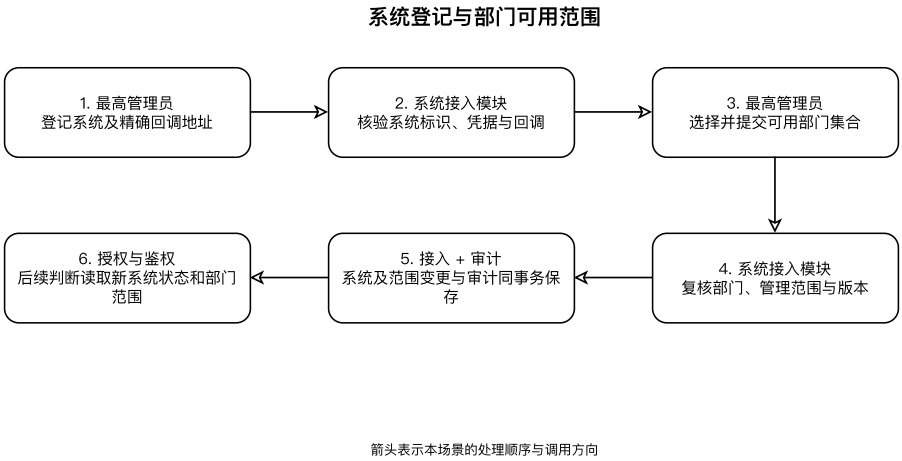


图 4-10 系统接入与部门范围变更场景流程图

备注：登记系统和替换可用部门集合分别校验版本。可用范围仅允许部门配置角色，并不直接给员工授予角色。

图中处理／实际方法	调用说明 URL	功能
AdminController.systems、system	GET /api/admin/systems、POST /api/admin/systems	查询或登记系统及认可的回调地址
AdminController.bind	POST /api/admin/systems/{id}/departments	以带版本的部门集合替换可用范围
AdminController.credentials	POST /api/admin/systems/{id}/credentials	必要时轮换系统接入凭据；凭据只在该次响应返回

4.2.10 权限目录接收与失败重报

用例编号： UPMS-REQ-PERM-001	用例名称： 接收、更新及停用目录权限
级别： 用户目标	
包： 权限目录	
参与者： 外部系统、最高管理员	
描述： 接收已识别系统来源的目录变更，不完整输入不覆盖已确认目录。	
触发事件： 外部系统首次接入或目录变更、失败后重新上报。	
前置条件： 系统已登记且允许接入；上报来源与目标系统匹配。	
主成功场景：	**信息**
1. 提交目录及变更含义。	系统提交的目录版本和明确变更
2. 校验系统归属、标识唯一和内容完整性。	系统归属、权限标识和目录完整性检查
3. 整体确认新目录。	确认后的目录及版本
4. 停用项从有效角色中排除，新增项不自动授予。	停用项和新增项对有效角色的影响
5. 返回确认结果并记录事件。	目录确认结果、失败信息和审计事件
扩展场景：	**处理及信息**
目录不完整、权限标识冲突或系统归属不匹配	整体拒绝，保留上一次确认的目录。
相同或过期的目录版本再次上报	相同版本且内容等价时幂等确认；过期版本或同版本不同内容拒绝，不回退现行目录。
外部系统未收到确认或修正后的目录上报失败	保留失败状态，允许修正后重报；不能显示为已确认。
后置条件： 确认后的停用项最多 3 秒影响后续鉴权。	
其他： 缺失项不自动视为删除，停用必须明确表达；重新启用项须重新配置角色才能恢复授予，防止旧配置意外恢复。	

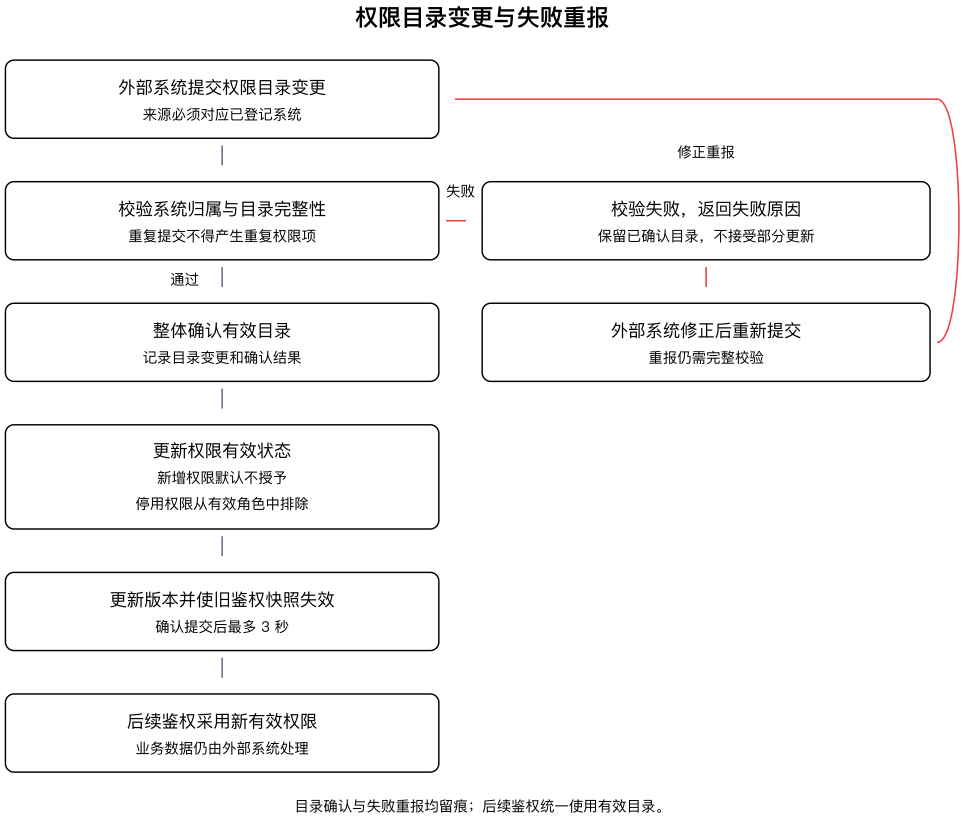


图 4-11 目录更新、停用及重报场景流程图

备注：来源、完整性或版本检查失败时保留旧目录；外部系统修正或重报，平台不能把“已收到请求”显示为“目录已确认”。

图中处理／实际方法	调用说明 URL	功能
框架 client_credentials 令牌端点	POST /oauth2/token	使用独立目录客户端身份取得专用令牌
DirectoryController.report	POST /api/directory/report	提交完整、递增版本的系统权限目录

4.2.11 全局角色模板

用例编号： UPMS-REQ-ROLE-001	用例名称： 维护全局模板
级别： 用户目标	
包： 角色管理	
参与者： 最高管理员	
描述： 按系统维护初始五类及后续模板。	
触发事件： 最高管理员新增、修改、停用模板。	
前置条件： 系统目录已确认；有效最高管理员会话。	
主成功场景：	**信息**
1. 选择系统与模板。	模板所属系统和名称
2. 从该系统有效权限中配置集合。	该系统有效权限集合
3. 校验同系统模板名称唯一。	同系统模板名称与权限状态检查
4. 保存并审计。	保存后的全局模板和审计事件
扩展场景：	**处理及信息**
选择跨系统权限或已停用权限	拒绝该权限集合。
模板已停用	不允许复制；修改模板不覆盖已有部门角色。
后置条件： 模板供复制，不能直接分配员工。	
其他： 模板的岗位名称不自动对应员工岗位或管理员身份。	

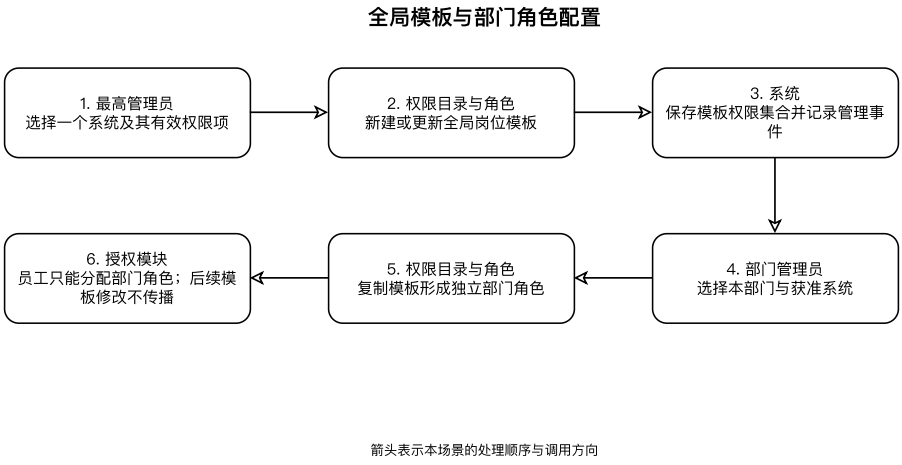


图 4-12 全局模板维护与复制场景流程图

备注：前半段是本用例的模板维护；后半段展示 ROLE-002 如何复制模板。副本独立维护，模板调整不覆盖已有部门角色。

图中处理／实际方法	调用说明 URL	功能
AdminController.roles、role	GET /api/admin/roles、POST /api/admin/roles	读取及维护全局角色模板与权限集合

4.2.12 部门角色

用例编号： UPMS-REQ-ROLE-002	用例名称： 新建、修改、停用部门角色
级别： 用户目标	
包： 角色管理	
参与者： 最高管理员、部门管理员	
描述： 在获准系统内复制模板或自建本部门角色。	
触发事件： 管理员提交部门角色配置。	
前置条件： 部门与系统有效且关系获准；操作者具有部门范围。	
主成功场景：	信息
1. 选择部门、系统。	部门、系统和当前可用关系
2. 复制有效模板或新增角色。	选定模板或新角色
3. 配置该系统有效权限。	该系统有效权限集合
4. 显示受影响员工数并保存。	受影响员工和保存后的部门角色
5. 最多 3 秒更新相关鉴权结果。	后续鉴权使用的新角色权限
扩展场景：	处理及信息
管理员越部门、跨系统或使用重复角色名	拒绝保存并保留当前角色。
停用角色仍有员工分配	保存停用状态后使该角色权限失效。
删除的角色仍有分配	拒绝删除，先要求处理现有分配。
后置条件： 角色独立于模板维护，不影响其他部门角色。	
其他： 无权限角色可保存供配置，但不能通过任何受控操作鉴权；重新启用前显示仍保留的分配及恢复影响。	

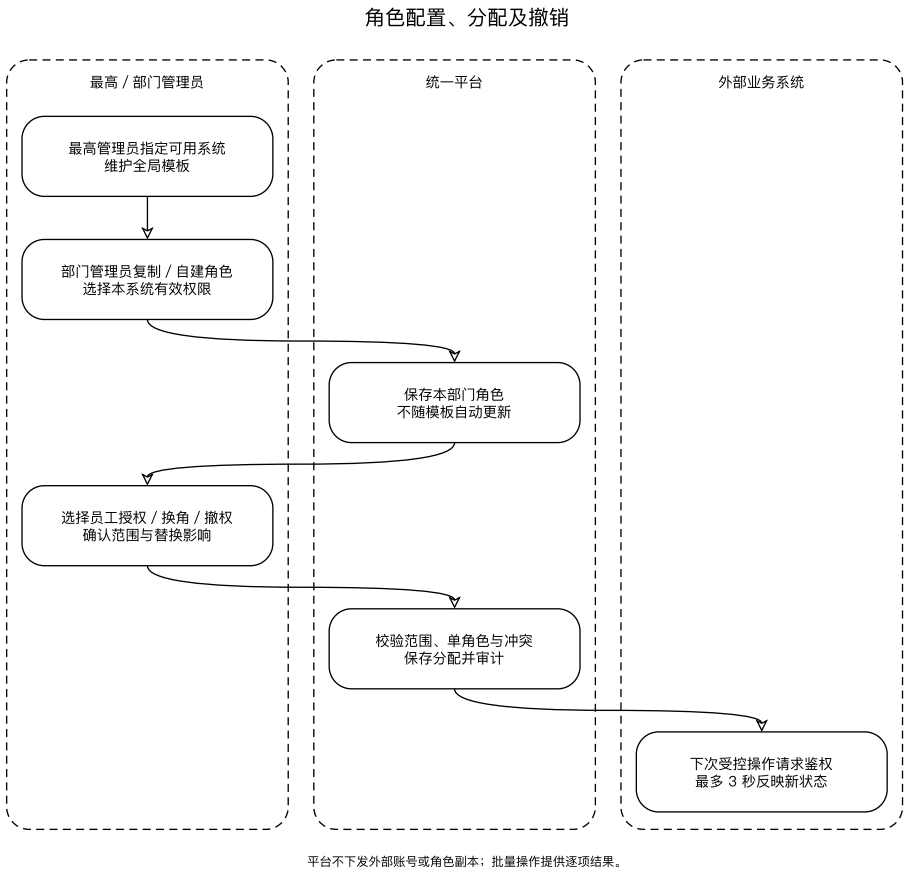


图 4-13 部门角色配置场景流程图

备注：前半段配置部门角色；末段员工分配和后续鉴权属于 GRANT-001、AUTHZ-001，用来标明角色配置的使用去向。

图中处理／实际方法	调用说明 URL	功能
AdminController.roles、role	GET /api/admin/roles、POST /api/admin/roles	按管理范围维护部门角色和权限集合
AdminController.copy、affected	POST /api/admin/roles/copy、GET /api/admin/roles/{id}/affected	复制模板并查看角色变更影响

4.2.13 角色分配与替换

用例编号： UPMS-REQ-GRANT-001	用例名称： 单个或批量分配、替换角色
级别： 用户目标	
包： 授权管理	
参与者： 最高管理员、部门管理员	
描述： 为员工在一个系统选择一个本部门角色，已有分配时明确替换。	
触发事件： 管理员选择员工、系统与目标角色并确认。	
前置条件： 员工有明确部门；员工、部门、系统、关系和角色有效。	
主成功场景：	**信息**
1. 筛选并勾选员工。	筛选结果、员工、系统和目标角色
2. 展示各人当前角色及目标角色。	各员工旧角色与替换影响
3. 有旧角色时提示替换。	旧角色被替换的明确确认
4. 确认后校验管理范围并处理分配。	管理范围、员工状态及并发版本检查
5. 展示逐人成功、失败及生效状态。	逐项成功 / 失败结果和生效期限
扩展场景：	**处理及信息**
所选员工或目标角色有一项超出管理范围	整批拒绝，不先处理合法子集。
范围内个别员工状态在提交前变化	该项失败并显示原因，其他成功项保留。
并发换角或版本已过期	拒绝旧版本写入，要求管理员刷新确认。
重复分配同一角色	保持单角色事实，不生成重复分配。
后置条件： 每员工每系统至多一个未撤销分配，成功项最多 3 秒生效。	
其他： 批量受理不等于全部成功；变更不创建外部账号。	

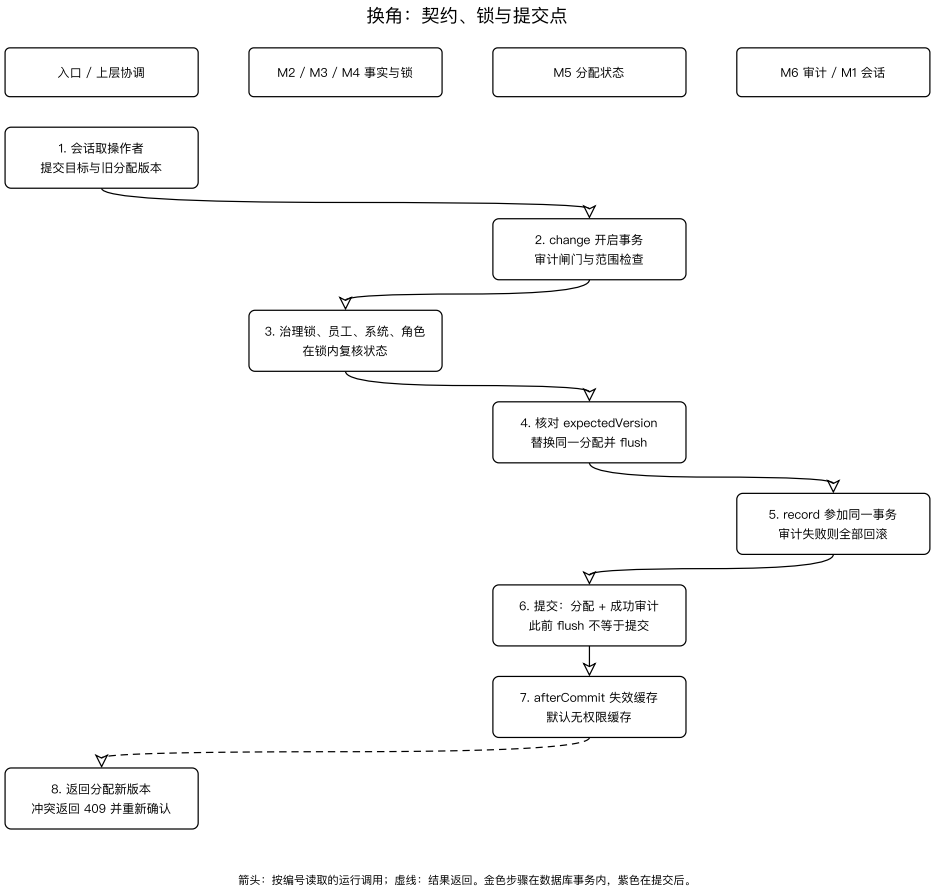


图 4-14 分配与并发换角场景流程图

备注：旧版本比较、单角色替换和成功审计都在提交前完成。图中 afterCommit 才表示提交后动作，flush 不等于提交。批量操作对每人分别返回结果。

图中处理／实际方法	调用说明 URL	功能
AdminController.assignment	POST /api/admin/assignments	单个员工分配或显式替换并发版本
AdminController.batch、retry	POST /api/admin/batches、POST /api/admin/batches/{id}/retry	批量执行及经确认的逐项重试

4.2.14 撤销角色

用例编号： UPMS-REQ-GRANT-002	用例名称： 单个、批量或全部系统撤权
级别： 用户目标	
包： 授权管理	
参与者： 最高管理员、部门管理员	
描述： 撤销所选员工在指定系统的角色，或撤销调动前全部系统角色。	
触发事件： 管理员确认撤权范围。	
前置条件： 有员工管理权限。	
主成功场景：	**信息**
1. 展示员工、系统和当前分配。	员工、系统和当前角色
2. 确认撤权。	管理员确认的撤权范围
3. 平台撤销目标分配并审计。	撤销后的分配状态及审计事件
4. 最多 3 秒后该范围内的后续鉴权拒绝。	后续鉴权的拒绝结论与生效期限
5. 显示逐项变更与生效状态。	逐项变更结果
扩展场景：	**处理及信息**
员工在目标系统没有分配	返回已无授权状态。
批次中包含越范围员工	整批拒绝。
个别撤权保存失败	显示失败项，已成功项不回滚；允许重试失败项。
后置条件： 撤销一个系统不影响其他系统角色，不结束身份会话。	
其他： 撤权与员工停用分别处理；员工停用影响所有系统及会话。	

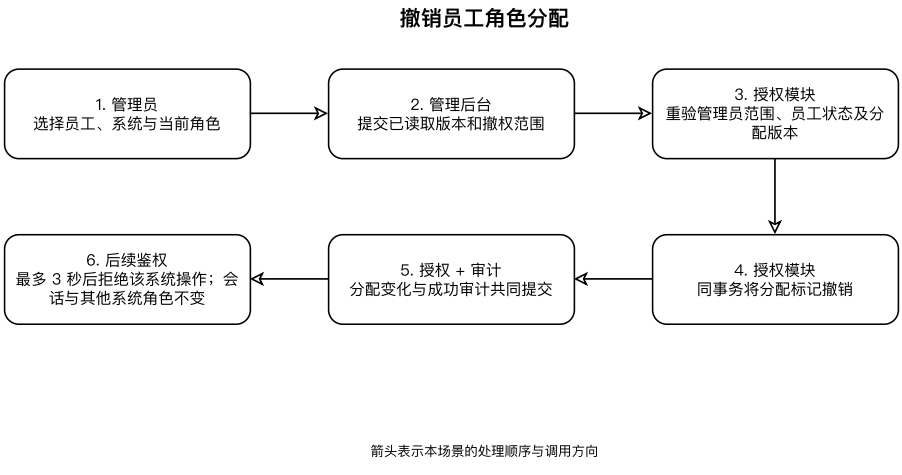


图 4-15 撤销角色场景流程图

备注：撤权修改当前分配并保留版本；它不终止统一会话，也不影响员工在其他系统的独立角色。

图中处理／实际方法	调用说明 URL	功能
AdminController.assignment	POST /api/admin/assignments	将目标角色设为空以撤销单个员工授权
AdminController.batch	POST /api/admin/batches	按目标范围批量撤权并保存逐项结果

4.2.15 运行时鉴权

用例编号： UPMS-REQ-AUTHZ-001	用例名称： 判断业务操作权限
级别： 子功能	
包： 授权与鉴权	
参与者： 外部系统	
描述： 平台对某员工在请求系统的功能点及动作返回允许或拒绝。	
触发事件： 外部系统后端准备执行受控操作。	
前置条件： 调用系统身份可信，能提供已验证员工及当前会话上下文。	
主成功场景：	**信息**
1. 核验调用系统与目标系统一致。	令牌验证出的系统、员工及会话身份
2. 核验会话未到期、未退出且员工有效。	统一会话、员工和登录状态
3. 核验系统、部门范围、分配、角色及权限项有效。	部门范围、分配、角色及权限项事实
4. 判断当前角色包含请求操作。	请求功能点与动作的匹配结果
5. 返回结论；外部系统仅在允许后执行业务操作及“本人”等范围校验。	允许 / 拒绝结论和外部系统后续处理
扩展场景：	**处理及信息**
身份、会话、系统、角色或权限项无效	返回拒绝，外部系统不执行受控操作。
平台超时、不可用或不能可靠判断	视为技术失败并拒绝操作，提示稍后重试。
员工身份有效但权限规则不匹配	返回业务拒绝，不作为技术失败统计。
后置条件： 拒绝和异常记录审计，允许结果计入统计；鉴权不修改角色。	
其他： 前端按钮隐藏不能替代后端鉴权。判断最多陈旧 3 秒；外部系统不独立长期缓存允许结果。	

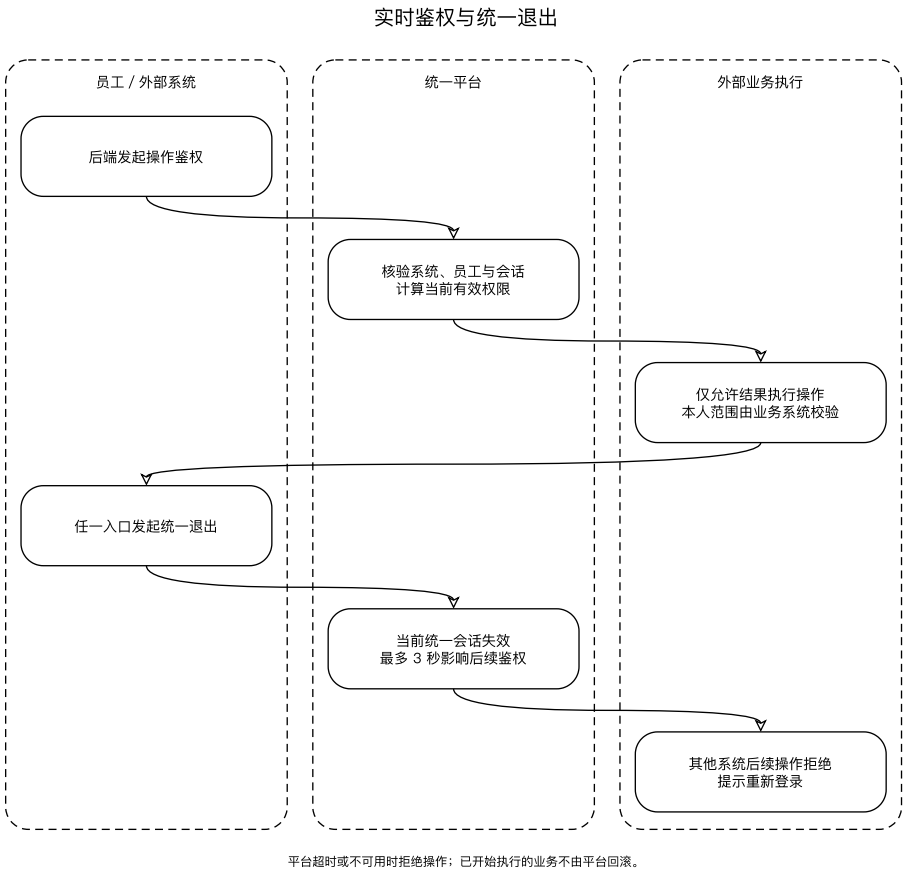


图 4-16 实时鉴权与故障拒绝场景流程图

备注：仅“明确允许”进入外部业务执行；图的后半段展示统一退出如何改变后续判断。身份无效或平台故障均不进入业务操作。

图中处理／实际方法	调用说明 URL	功能
RuntimeController.check	POST /api/runtime/check	每次受控操作前提交目标系统和权限标识；员工身份来自已验证令牌
BusinessController.read、write	POST /documents/read 或 POST /documents/write	仅在平台明确允许后执行业务操作；记录归属范围仍由业务系统判断

4.2.16 查询有效角色与权限

用例编号： UPMS-REQ-QUERY-001	用例名称： 查询员工各系统角色和有效权限
级别： 用户目标	
包： 查询	
参与者： 最高管理员、部门管理员	
描述： 按员工、部门、系统、角色和状态查看授权及失效原因。	
触发事件： 管理员筛选或查看详情。	
前置条件： 有效管理员会话及相应员工范围。	
主成功场景：	**信息**
1. 按范围筛选。	管理员筛选条件及员工范围
2. 显示每系统角色、权限及角色 / 系统 / 部门范围状态。	员工逐系统角色、权限和有效状态
3. 查看配置变更时间和最迟生效时间。	配置时间、失效原因及最迟生效时间
扩展场景：	**处理及信息**
员工没有角色或角色不再有效	显示未授权及可说明的失效原因。
查询目标超出管理员范围	拒绝查询并留下范围拒绝记录。
后置条件： 不改变业务配置。	
其他： 查询使用与鉴权相同的有效权限规则，不查询外部账号副本。	

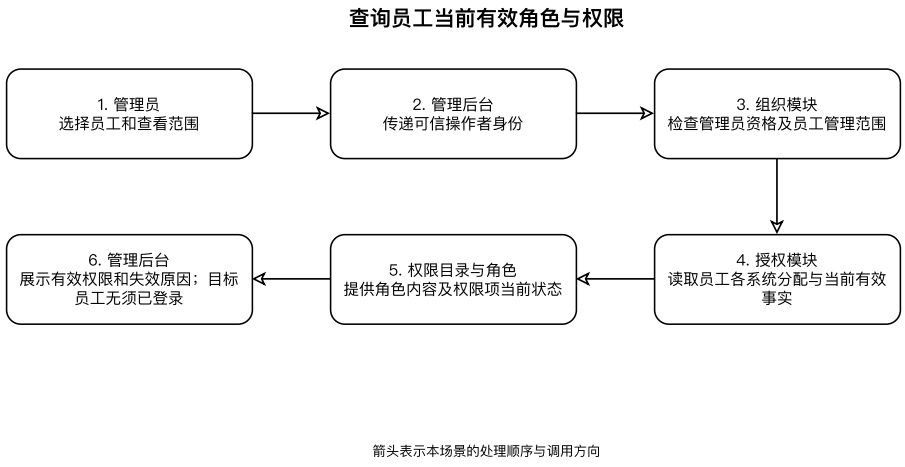


图 4-17 有效角色与权限查询场景流程图

备注：查询先确定操作者的员工管理范围，再组合当前有效事实；目标员工无需正在登录，查询也不会产生授权。

图中处理／实际方法	调用说明 URL	功能
AdminController.employeePermissions	GET /api/admin/employees/{id}/permissions	在员工管理范围内查看逐系统有效角色、权限与拒绝原因
AdminController.affected	GET /api/admin/roles/{id}/affected	查看角色变更影响范围

4.2.17 审计查询与导出

用例编号： UPMS-REQ-AUDIT-001	用例名称： 查询、查看和导出审计记录
级别： 用户目标	
包： 审计	
参与者： 最高管理员、部门管理员	
描述： 查询认证、退出、管理变更、目录确认、鉴权拒绝和异常。	
触发事件： 管理员筛选、查看详情或导出。	
前置条件： 有效管理员会话及日志管理范围。	
主成功场景：	**信息**
1. 按时间、操作者、部门、系统、事件和结果筛选。	时间、操作者、部门、系统、事件和结果条件
2. 返回范围内记录。	范围内的日志记录
3. 查看变更前后内容、失败原因和关联事件。	变更前后内容、失败原因和关联事件
4. 导出当前筛选结果并记录导出行为。	筛选结果、CSV 下载及导出审计事件
扩展场景：	**处理及信息**
查询或导出目标超出日志范围	拒绝请求并留下范围拒绝记录。
日志没有员工或部门归属	仅最高管理员可见。
导出发生故障	提示重试，不修改原审计记录。
后置条件： 原记录不变，查询与导出留痕。	
其他： 不记录登录凭据原文或可复用会话凭据；允许鉴权仅统计，不逐条记录。	

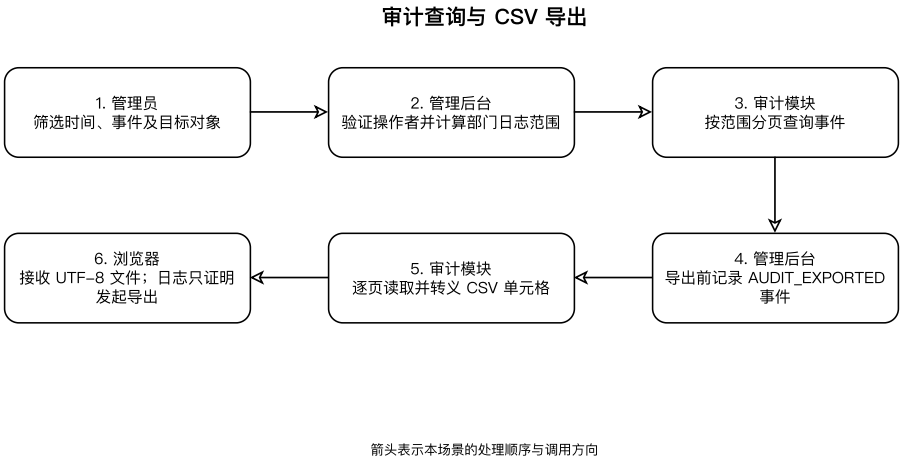


图 4-18 审计筛选与导出场景流程图

备注：导出开始前写入审计，再读取并转义 CSV 内容；导出审计只能证明发起过导出，不能证明网络下载一定完成。

图中处理／实际方法	调用说明 URL	功能
AdminController.audit	GET /api/admin/audit	按授权范围和筛选条件分页查询日志
AdminController.export	GET /api/admin/audit/export	记录导出发起后逐页生成转义 CSV 下载

4.3 业务流程

4.3.1 总体流程

4.2 节每项用例后紧接场景图和对应接口调用说明。图 4-19 有员工登录与管理员配置两个独立起点；两条路径在运行时鉴权处汇合。实线表示请求或处理，虚线表示读取当前权限事实。

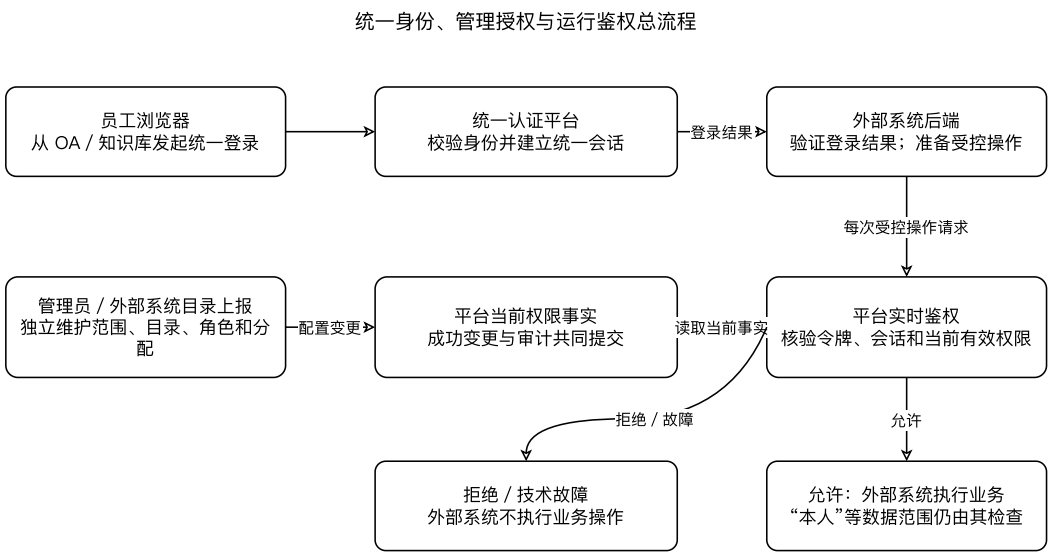


图 4-19 统一登录、管理授权、实时鉴权与变更留痕总流程

阅读时先沿上方查看登录和鉴权，再沿左下方回看权限事实的来源。认证身份不自动带来业务权限；管理员已保存的变化会影响后续鉴权，已经开始的业务操作仍由外部系统负责。

4.4 模块与对象详细设计

采用模块化单体，使用 Spring Boot、Spring MVC、Spring Data JPA 与 MySQL。DFD 的 P1、P2、P4、P5 分别对应身份、组织、授权、审计；P3 按接入配置与权限内容拆为 M3、M4。各模块按规则归属划分，模块内保留 Controller、Service、Repository 等实际需要的层次。

模块与包	公开能力／主要对象	责任与隐藏状态
M1 identity	IdentityApi；IdentityService 及 OIDC 安全配置	验证浏览器、员工令牌、目录令牌；维护统一会话和失效。隐藏内存索引与协议实现，不判断业务角色
M2 organization	OrganizationApi；OrganizationService	公司、部门、员工、管理员身份和范围；公开员工事实与范围检查，隐藏 JPA 实体及 Repository
M3 integration	IntegrationApi；IntegrationService	系统登记、回调、独立凭据与部门可用关系；提供可信系统事实
M4 catalog	CatalogApi；CatalogService	完整目录、全局模板、部门角色和权限选择；分配归 M5，模板复制后独立
M5 authorization	AuthorizationApi、BatchApi；AuthorizationService、EffectivePermissionRule、BatchService	单角色写入、批量结果、权限事实读取与纯判断；规则不接收 HTTP 请求或 JPA 实体

模块与包	公开能力／主要对象	责任与隐藏状态
M6 audit	AuditApi；AuditService	同步事件记录、范围查询、导出、可用性闸门及统计；不反向查询业务模块
应用协调 application	AdminController、RuntimeController、DirectoryController、EmployeeLifecycle	路由与可信身份转换、跨模块生命周期和影响检查；不拥有各模块实体及 Repository



图 4-20 模块公开能力的允许依赖

矩阵行是调用者、列是被依赖模块。跨模块仅访问 api 包，不访问内部实体、Repository 或缓存；应用协调层按用例组合能力，模块不反向依赖协调层。Java 使用编号关联不妨碍数据库设置外键。

Controller 处理传输形式和身份入口，Service 执行范围、规则和事务，Repository 负责本模块持久化。请求 DTO、模块事实 record、JPA 实体和表按职责转换，不要求数量一一对应。Spring 单例服务不在共享可变字段保存当前员工或请求参数。

4.5 接口与关键处理设计

4.5.1 接口层次与失败语义

接口	调用者与输入来源	当前设计
模块 Java 契约	同进程模块；显式传递经入口验证的操作者或系统事实	OrganizationApi、CatalogApi、AuthorizationApi 等；返回事实对象，事务与锁前提由契约规定
HTTP 业务接口	浏览器后台会话，或系统 Bearer 令牌	后台 /api/admin/、实时 /api/runtime/check、目录 /api/directory/report；详细方法与 URL 紧接各用例流程
OIDC 协议端点	已登记客户端及浏览器重定向	框架提供发现、授权、令牌、公钥、用户资料、内省及 RP 退出；不另造协议替代

后台操作者从服务端会话取得，鉴权员工从有效访问令牌取得，目录系统从独立目录令牌取得；不接受前端任意指定身份。后台写请求携带 GET /api/csrf 返回的 token，头名采用返回的 headerName。写入结果不能作为绕过下一次鉴权的授权凭据。

结果	HTTP 业务入口表达	调用方动作
身份有效但无权限	200，allowed=false，含拒绝原因	拒绝业务操作，按正常权限拒绝统计
身份 / 会话失效	401	重新登录，不替换员工编号重试
管理越范围 / 系统不匹配	403	停止操作
旧版本 / 状态冲突	409	刷新并重新确认，不自动覆盖
审计故障等不可确认	503	拒绝受控操作并提示重试

业务异常由 FailureAdvice 转为 ProblemDetail 并提供 code；Bean Validation 分支当前未附加 code。框架登录与 OIDC 端点遵循各自协议，不承诺全站统一 JSON。

4.5.2 登录与统一会话

客户端采用授权码与 PKCE S256，核验 state、nonce、签名及精确回调。授权码 60 秒，AtomicCodeExchange 补充原子兑换保护，同一码并发兑换仅一次成功。不透明访问令牌保存在业务系统后端，不发行刷新令牌；ID Token 不含可替代实时鉴权的业务权限。

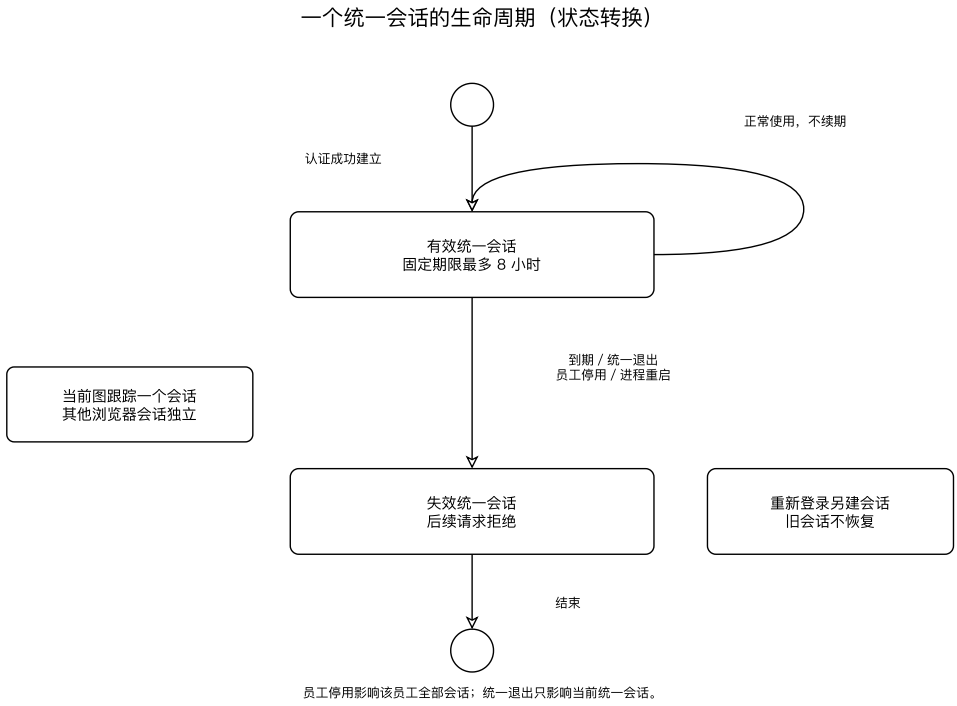


图 4-21 统一会话生命周期

会话固定最多 8 小时，访问不续期，令牌不晚于所属会话到期。RP 退出清本地会话后访问平台 connect/logout，失效当前统一会话；其他浏览器会话独立。员工停用撤销全部会话。重启后内存会话与令牌失效，持久化业务事实保留。

4.5.3 授权、鉴权与缓存

AuthorizationApi.change 接收操作者、目标员工、系统、目标角色和 expectedVersion。roleId 为空表示撤销；首次无分配时旧版本为 -1。事务内重新校验范围、员工、系统、部门可用关系和角色归属，核对旧版本，保存唯一分配与成功审计，提交后失效相关缓存。并发旧版本请求返回冲突。

运行时先由 IdentityApi.token 核验令牌、统一会话、员工状态和系统归属，再由 AuthorizationService 装配事实，交 EffectivePermissionRule 判断。员工、系统、部门范围、分配、角色和权限全部有效且含目标动作才允许。管理员查询不要求目标员工已登录，但须检查操作者管理范围。

默认缓存关闭；可选 Caffeine 单节点有界缓存以最早事实读取开始计算 2 秒绝对期限，命中不续期，提交后主动失效仅加速。多次 READ_COMMITTED 查询不是全库同一时刻的原子快照；正确性按变更后 3 秒上限验证。技术故障不回退到过期允许结果。

4.5.4 目录、角色与批量

目录完整上报最多 10,000 项，已有效旧项不能遗漏，停用须显式声明。同版本内容等价才幂等确认；旧版本、同版本不同内容和不完整目录整体拒绝。新权限不自动授予，停

用权限从现有角色选择中移除。角色 permissions 采用显式集合替换，模板复制后不再联动，删除采用逻辑删除且先检查无员工分配。

批量每次 1 至 100 名不同员工，先整批范围预检，再在当前请求内逐人处理，不使用异步消息队列。每项分配、成功结果与审计共同提交，部分失败保留成功项。重启后待处理项标为中断，明确重试仅接受失败 / 中断项的新确认版本。

requestKey 与操作者共同标识提交，同 key 不同意图拒绝。当前重试会更新明细旧版本，因此重试后重放最初提交可能冲突；不承诺永久重放兼容。不可变原始请求摘要属于后续改进，不是当前实现。

4.5.5 员工停用、调动与审计

EmployeeLifecycle.state 在同一事务中修改员工、撤销全部分配、写成功审计；提交后调用 M1 撤销全部会话。任一持久化步骤失败则整体回滚，不执行提交后动作。提交后内存失效异常不得重新启用员工抵消，后续鉴权仍按员工状态及绝对期限拒绝。过程见图 4-7。

调动是人工多步骤流程：原部门撤完所有系统角色并等待 3 秒，取消旧部门管理员身份，最高管理员校验版本及前提后修改部门，新部门重新授权。调动与并发授权使用共同锁序，不能以长事务等待人工操作，见图 4-8。

正常管理变更与审计同事务保存。审计不可用时回滚变更，不确认新登录成功并暂停新受控请求；实际退出不恢复，故障与恢复可识别，明确审计缺口，不承诺补录。允许鉴权只统计，拒绝和异常同步留痕，日志范围由服务端强制限制。

5 性能需求

5.1 数据精确度

1. 身份资料唯一性、归属和每员工每系统单角色约束在并发操作下仍成立。
2. 不因同名公司岗位、部门、系统角色或模板而合并身份或权限。
3. 有效权限由当前状态组合得到，不将登录成功、部门可用系统或模板存在视为已授权。
4. 重复目录上报、授权、撤权或退出不产生重复授权，也不恢复已撤销权限。
5. 权限错误按零容忍验收；技术失败率预算不能用于容忍错误允许。
6. 批量操作保留逐项结果；管理成功与缓存生效期限分别展示。

5.2 时间特性

5.2.1 性能目标

以下为验收目标；本机已有测量的条件与结果见《最终验收报告》，服务器部署不继承该容量结论。

编号	工作负载与时长	指标与边界
ACC-P-001	10,000 个不同有效账号在 60 秒内均匀发起首次完整登录，之后等待全部请求结束	完整登录 P95 ≤ 3 秒，技术失败率 ≤ 1%；统计成功数、失败数、超时数、最大耗时及实际发起速率。
ACC-P-002	10,000 个已登录账号轮转产生 1,000 次 / 秒鉴权，持续 5 分钟，共计划 300,000 次	平台鉴权调用 P95 ≤ 300 毫秒，技术失败率 ≤ 1%；实际发送量和完成量须报告，不用排队积压掩盖未达吞吐量。
ACC-P-003	100 名管理员并发执行常用查询与单项操作，持续 5 分钟	查询、详情和单项管理操作 P95 ≤ 3 秒；无唯一性、单角色及隔离错误。
ACC-P-004	ACC-P-002 持续鉴权期间，同时施加 ACC-P-003 的管理员负载	两类请求分别统计，并各自满足其指标；登录峰值可单独测试。
ACC-P-005	在持续鉴权下进行授权、换角、撤权、角色变更、目录停用、员工停用、部门可用系统范围取消、管理员身份取消及统一退出	从变更成功提交或退出确认起，最迟 3 秒后的每次新鉴权或后台管理请求必须反映新状态；旧允许结果不能因反复访问续期。

完整登录从测试客户端发起业务系统登录跳转开始，至业务系统后端验证结果并建立身份关联结束，包含跳转、认证和验证，排除人工输入等待。采用自动提交已准备凭据，不能只测单次身份匹配。

鉴权延迟从业务系统后端发出调用到收到可执行结论，包含平台会话与权限校验。本地测试排除外网延迟，仍包含本机通信和必要的数据读取。

常用管理员操作的基准构成为：员工或授权列表 40%、角色或权限详情 30%、单人授权 / 换角 / 撤权 20%、员工资料更新 10%。每名虚拟管理员收到结果后等待 1 秒再执行下一操作。鉴权基准为有效允许 80%、缺少操作权限的预期拒绝 20%，分布到两个模拟系统；另独立验证停用、未知权限、跨系统及失效会话。

批量提交最多 3 秒返回已受理结果并持续提供逐人状态。每个成功项从其提交完成起计算 3 秒生效窗口，不要求整批在 3 秒内处理完毕。

5.2.2 复现与结果报告

1. 使用 10,000 人、17 系统目录基线；压测身份须有明确的部门和测试角色，可在测试副本中为 54 名直属员工明确归属，记录处理，不能改写来源表格。
2. 会话绝对到期、系统返回目标和测试授权在测试开始前准备完成。首次登录测试清空登录会话，并分别报告冷启动及预热情况。
3. 持续鉴权先预热 30 秒，正式统计其后 5 分钟；负载发生器按设定速率发起，不以系统变慢自动减少负载。
4. 记录硬件、操作系统、运行时、应用及数据库配置、负载发生器位置、数据准备、网络条件和缓存条件。同机压测说明客户端与服务端争用资源。
5. 延迟报告 P50、P95、最大值，并单列失败、超时及未完成请求。技术失败按计划应完成的请求或完整登录次数计算，预期拒绝独立计数。
6. 测试客户端超时上限：完整登录与管理员操作 10 秒、单次鉴权 3 秒。超时计失败；失败不能通过重新发送后从原统计中消失。
7. 功能正确性、3 秒生效上限、吞吐与延迟各自验收。指标失败时记录瓶颈及改进后结果，不以平均响应替代 P95。

5.3 适应性

平台可在 17 个系统基础上继续登记系统，接收不同目录，建立不同部门角色。新增系统和权限不需要统一为所有系统相同的功能集合。

单系统角色规则保持一致，跨系统权限分别计算。后续如采用多角色、直接个人权限或新组织层级，需要明确修改需求基线。本期不预置这些能力。

6 运行需求

6.1 软件接口

本节规定交换责任；当前端点见第 4.2 节，操作契约与关键处理见第 4.5 节。

方向	交换目的	责任与结果
业务系统 / 浏览器到平台	发起统一登录并指定认可的返回目标	平台识别发起系统，认证或复用会话，返回限定于该系统的登录结果。
业务系统后端到平台	验证登录结果	平台防止过期、跨系统、篡改和重复兑换，返回可用于业务识别的统一身份。

方向	交换目的	责任与结果
业务系统后端到平台	请求操作鉴权	校验系统身份与员工会话，只判断该系统登记的操作；返回允许、拒绝或无法确认。无法确认时外部系统拒绝执行。
用户 / 业务系统到平台	统一退出	平台使当前统一会话失效；业务系统清理本地关联，其余系统在后续请求中识别失效。
外部系统到平台	权限目录新增、变更、停用或重报	平台校验来源、完整性和变更顺序，整体确认或整体拒绝，保留可查询接收记录。
管理后台到平台	管理与查询	服务端校验管理员身份及对象范围，返回逐项结果、配置状态、生效期限或审计记录。

系统调用须具有可信系统身份。外部系统不能凭前端传入的任意员工身份代替已验证会话，不能验证或查询其他系统的登录结果和权限。

外部系统负责业务数据、前端交互、操作执行和“本人”等记录范围校验。平台不保存业务记录，不参与业务事务回滚。

6.2 故障处理

情况	要求
统一认证入口失败	不建立已成功会话，提示重新发起；业务系统不使用未验证身份。
鉴权超时或不可用	拒绝受控操作并提示重试；不沿用超过期限或无法确认的允许结果。
目录不完整、重复或乱序	失败保留已确认目录；同版本等价内容幂等确认；同版本不同内容或过期版本拒绝。
目录确认响应丢失	外部系统重报同一变更并取得明确结果，不将未收到响应视为停用已生效。
管理保存失败	不显示成功，不留下双角色或范围冲突；失败项可重新提交。
并发授权、换角或调动冲突	拒绝冲突变更并说明对象已变化，要求刷新；不能以最后一次覆盖代替冲突检测。
缓存不可用或失效更新失败	读取可靠新状态或拒绝，不能延长旧允许状态；3 秒上限仍适用。

情况	要求
统一退出未确认	清理当前系统关联，提示全局退出未确认；平台不可用期间受控操作拒绝。
审计存储失败	成功管理变更与审计一致保存，审计失败时该变更不提交、不报告成功；不确认新登录成功，暂停新的受控操作并明确提示。已结束的会话不因审计失败恢复，分别说明退出状态与记录失败。通过运行提示及诊断明确故障和审计缺口，恢复后重新校验，不宣称缺失事件已完整补录。本期不要求可靠暂存与恢复补录。

无需恢复已经执行的外部业务操作，也不要求故障期间绕过鉴权维持业务。恢复后请求重新校验，不自动恢复撤销授权。

6.3 部署设计

Manager（113.44.144.119）运行平台单实例和 Nginx；Node1（119.3.221.88，内网 172.31.12.231）运行专用 MySQL 8.4、OA 和知识库。两个模拟系统不连接平台数据库。平台使用内网数据库连接；外部 HTTPS 入口分别为 443、8443、9443，issuer 为 https://113.44.144.119。

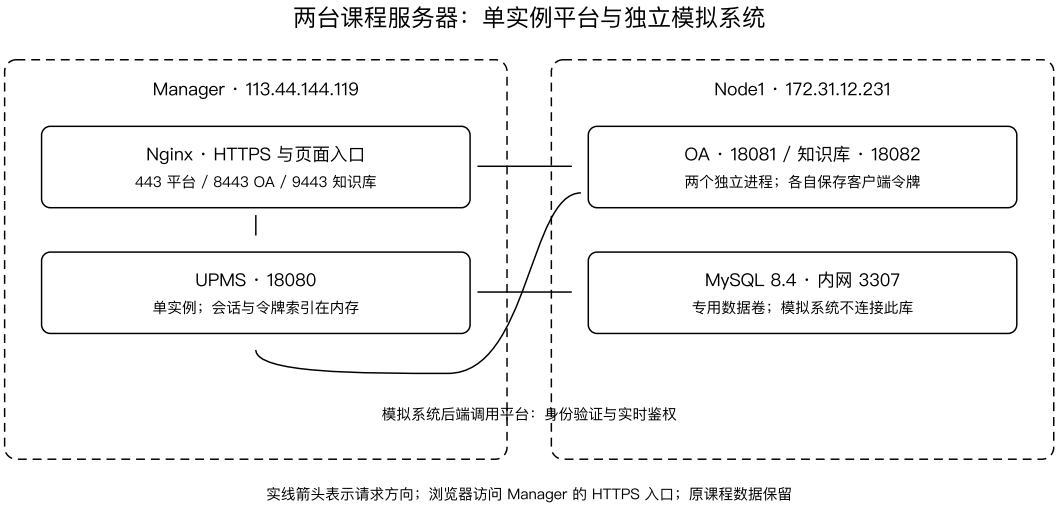


图 6-1 两台课程服务器的运行分配

箭头表示运行请求方向。例如 OA 后端向平台发送实时鉴权，平台从 Node1 的专用 MySQL 读取事实；浏览器不直接访问数据库。Nginx 覆盖转发头，应用只信任指定代理；会话 Cookie 为 Secure、HttpOnly，三个应用使用不同名称。

Manager 的平台容器限额 1024 MiB、最大堆 512 MiB；Node1 的 MySQL 限额 512 MiB，两个客户端各限额 384 MiB、最大堆 128 MiB。配置见 infra/server/。这些是课程服务器的初始资源配置，不表示已满足本机正式压测目标。

IP 证书采用 Let’s Encrypt shortlived，约 160 小时有效，每六小时检查续期并重载代理。申请失败、续期失败或外网不可达都列为部署问题，不能通过关闭证书验证解决。平台重启后旧会话和令牌拒绝，持久化配置保持；重新登录后恢复操作。

原有 lab_mysql 和 lab_productdemojpa 暂停副本，原数据卷保留；监控继续运行。停止本项目后依次执行恢复脚本的 manager、node、services 步骤即可恢复原课程服务。生产式高可用与容灾不在本课程交付范围。

6.4 测试与报告

手动运行、打开报告和排查步骤见 手动运行 JaCoCo 测试。

./scripts/coverage.sh 使用真实 MySQL 重跑两个后端模块，生成 HTML、XML、CSV 并对行和分支分别执行 100% 门禁。--baseline 只用于诊断，明确跳过门禁，不能作为验收通过证据。报告元数据记录源提交、差异摘要、工具版本和运行时间。JaCoCo 统计全体手写后端生产代码，压测工程和第三方代码不计入。

单元测试检查规则与错误分支；MockMvc 契约测试检查路由、JSON、可信身份传递和凭据隐藏；真实 MySQL/OIDC 测试检查唯一约束、事务、范围、授权码竞争与退出；ArchUnit 检查模块边界；浏览器检查操作流程。覆盖率达到 100% 仍需这些断言和场景验证，不能据此推断无缺陷。最终实测值和公网链接见《口试交付验收报告》。

7 其它需求

7.1 可用性

统一登录页显示发起系统和失败提示。后台支持常用筛选，明确区分未授权、配置失效、变更已提交和最迟生效期限。

批量操作、换角、停用、范围取消及统一退出需说明目标与影响后再确认。错误信息给出可执行的下一步，不显示凭据或技术堆栈。

7.2 权限隔离与安全

1. 范围校验覆盖列表、详情、变更、批量、日志和导出，不能仅隐藏菜单。
2. 系统调用身份、员工身份会话、部门管理范围和业务权限分别校验。
3. 未知、缺失、停用或无法确认的权限默认拒绝。
4. 平台管理员不自动成为外部系统管理员；五类模板也不代表平台身份。
5. 登录资料、可复用会话凭据不进入 URL、日志或导出。返回目标只能选已认可目标。
6. 员工停用影响全部会话，统一退出影响当前会话；管理员身份取消仅移除后台管理能力，不撤销员工正常业务角色。

7. 会话在不同系统的关联必须接受统一状态校验，外部系统不得独立延长统一会话期限。

7.3 审计与一致性

认证、退出、组织及员工维护、管理员任命、系统范围、目录确认及失败重报、模板和部门角色、授权撤销、鉴权拒绝和异常均可追溯。管理事件包含操作者、时间、范围、对象、变更前后及结果；登录失败记录避免保存凭据原文。

部门管理员仅能查询本部门关联事件；跨部门调动保留原、新归属，按各部门当时的事件范围查看。系统级及无法归属事件仅最高管理员可见。

运行统计包含调用量、允许、预期拒绝、技术异常及耗时。允许鉴权不逐条留痕；拒绝与异常不能被成功吞吐量掩盖。正常服务期间关键事件同步留痕；审计不可用时按第 6.2 节处理，并明确故障期间记录完整性未知。可靠暂存、恢复补录及去重属于后续扩展。

7.4 功能验收

编号	场景及预期	对应用例
ACC-F-001	装载 10 公司、101 部门、10,000 员工及 17 外部系统；54 名公司直属员工明确标记，无丢失、错配	ORG-001、EMP-001、SYS-001
ACC-F-002	用户名 / 手机号缺失、不匹配、员工停用均拒绝；身份正确的普通员工只能使用认证入口	AUTH-001、AUTH-002
ACC-F-003	A 登录后进入 B 免重复输入；B 单独验证身份与权限，A 的登录结果不能被 B 兑换	AUTH-002、AUTH-003
ACC-F-004	登录结果过期、篡改、重复兑换或返回目标未认可均拒绝	AUTH-002
ACC-F-005	同一会话在 A 统一退出后，B 最迟 3 秒拒绝新操作；8 小时到期须重新登录	AUTH-003、AUTH-004
ACC-F-006	其他浏览器独立会话不因当前会话退出失效；员工停用使所有会话最迟 3 秒失效	AUTH-004、EMP-001
ACC-F-007	部门管理员跨部门查询、改角色、授权、批量或导出均拒绝；最高管理员可代办	ADM-001、GRANT-001、AUDIT-001

编号	场景及预期	对应用例
ACC-F-008	部门可用多个系统，同系统供多个部门使用；移除范围最迟 3 秒使相关权限失效	SYS-001、AUTHZ-001
ACC-F-009	模板不能直接分配；复制后修改模板不改变部门角色；改某部门角色不影响其他部门	ROLE-001、ROLE-002
ACC-F-010	每员工每系统单角色，换角提示替换；跨系统角色独立；并发换角不静默覆盖	GRANT-001
ACC-F-011	批量越范围整批拒绝；有效范围内部分失败显示逐项结果，重复提交不产生重复分配	GRANT-001、GRANT-002
ACC-F-012	无角色、角色无权限、未知动作、停用项及跨系统请求均拒绝；“本人”记录范围由模拟系统执行	AUTHZ-001
ACC-F-013	目录停用最迟 3 秒影响已登录员工；新增权限不自动授予；失败保留旧目录，重报不回退	PERM-001、AUTHZ-001
ACC-F-014	撤权保留身份登录、拒绝对应系统操作；员工停用撤销所有分配并阻止登录	GRANT-002、EMP-001
ACC-F-015	调动前核对全部角色已撤销并生效、取消旧部门管理员身份；零业务角色也须走调动校验，调动后不继承角色或部门管理员身份	EMP-002
ACC-F-016	断开鉴权服务、制造超时后，模拟系统拒绝业务操作，恢复后重新判断	AUTHZ-001

编号	场景及预期	对应用例
ACC-F-017	正常服务时登录、退出、管理变更、目录失败、鉴权拒绝与异常可查询导出；部门日志隔离，允许鉴权只统计。制造审计存储故障，验证管理变更未提交且未报告成功，新登录未确认成功，新受控操作被拒绝；退出已结束的会话不恢复，并提示审计失败。故障与恢复可识别，审计缺口明确；恢复后重新校验，不要求完整补录	AUDIT-001
ACC-F-018	唯一资料冲突、最后管理员取消、系统身份冒用均被阻止并可追溯	EMP-001、ADM-001、AUTHZ-001

表内业务域编号均补全为 UPMS-REQ- 前缀定位。性能验收另按第 5.2 节执行。

7.5 课程演示与文档检查

使用 OA 和企业知识库两个模拟系统，各选取少量真实目录功能，演示不同操作权限。模拟系统只实现展示、受控操作和接入验证，不覆盖完整 OA 或知识库业务。

验收时讲清员工身份、角色权限和业务数据范围的区别；展示普通员工登录、管理后台授权、即时拒绝、3 秒撤权、跨系统复用与统一退出。

文档检查包括：七章结构和用例信息完整；图号、链接及需求编号可定位；上下文与各级 DFD 的信息流平衡；业务流程与有效权限规则一致；复杂图的 draw.io 与 SVG 内容一致。

依据配套指南检查需求、模块、代码位置和验证场景。测试门禁、运行结果及尚未通过项分别见《口试交付验收报告》；设计目标不能代替实测证据。